

UNIVERSIDAD TÉCNICA ESTATAL DE QUEVEDO

Facultad de Ciencias de la Ingeniería
Carrera de Ingeniería de Software (Rediseño)

ASIGNATURA: Aplicaciones Web

Quinto Nivel — Período Académico 2026-2027 PPA

ESPECIFICACIÓN DE REQUISITOS DE SOFTWARE (SRS)

Estándar ISO/IEC/IEEE 29148:2018

Sistema de Gestión de Pre-Sustentaciones UTEQ

Versión 1.0.1

Repositorio: <https://github.com/carla22072004/PFC-Presustentaciones-2026>
Punto del historial: etiqueta v1.0.1, *commit* 9d7abbd
Rama principal al cierre: *commit* 3e7069c (2026-09-09)
DOI del software: [10.5281/zenodo.22445216](https://doi.org/10.5281/zenodo.22445216)

AUTOR:

Álava Alvarado, Jean Pierre
[ORCID: 0009-0001-2878-2919](https://orcid.org/0009-0001-2878-2919)

DOCENTE-DIRECTOR:

Ing. Guerrero Ulloa Gleiston Cícron, Mg.

FECHA DE EMISIÓN: 11 de septiembre de 2026

Índice

1. Identificación y control del documento	3
1.1. Historial de versiones	3
1.2. Alcance de esta versión y punto de corte	3
1.3. Autoridad de cada artefacto	4
2. Introducción	4
2.1. Propósito	4
2.2. Alcance del sistema	4
2.3. Definiciones, acrónimos y abreviaturas	4
2.4. Convención de redacción normativa	5
2.5. Vocabulario cerrado de estado del requisito	5
2.6. Métodos de verificación	6
2.7. Referencias	6
3. Descripción general	7
3.1. Perspectiva del producto	7
3.2. Actores del sistema	7
3.3. Restricciones de diseño	8
3.4. Supuestos y dependencias	8
4. Interfaces externas	8
4.1. Interfaces expuestas	9
4.2. Interfaces consumidas	9
5. Catálogo de estados del dominio y transiciones	10
5.1. Solicitud de pre-sustentación	10
5.2. Acta de pre-sustentación	11
5.3. Tutoría, fase de tutoría y demás entidades	11
6. Matriz de permisos por rol y operación	11
6.1. Modelo de autorización	12
6.2. Asignación normativa de permisos	12
6.3. Acceso que no depende del catálogo de permisos	13
6.4. Asimetrías declaradas	13
7. Requisitos funcionales	14
7.1. Autenticación y gestión de la sesión	14
7.2. Identidades y autorización	19
7.3. Solicitud de pre-sustentación	21
7.4. Anteproyecto y tutoría	25
7.5. Tribunal, cronograma y salas	29

7.6. Evaluación por rúbrica	32
7.7. Acta de pre-sustentación	35
7.8. Comunicación y apoyo al usuario	38
7.9. Centro de orientación de titulación	41
7.10. Catálogos académicos y directorio	44
7.11. Reportes, observaciones y auditoría	46
7.12. Continuidad: respaldo y recuperación	49
8. Requisitos no funcionales	51
8.1. Rendimiento y eficiencia	52
8.2. Seguridad	54
8.3. Trazabilidad y protección de datos	61
8.4. Mantenibilidad, usabilidad y operación	63
9. Trazabilidad y verificación	66
9.1. Cláusula de verificación	66
9.2. Salida del validador sobre este árbol	67
9.3. Estructura de la matriz de trazabilidad	67
10. Estado de cumplimiento del corpus	68
10.1. Distribución por estado y prioridad	68
10.2. Requisitos <i>Must</i> que no están verificados	68
10.3. Nota metodológica sobre el crecimiento del corpus	69
11. Correspondencia con el Anexo C de ISO/IEC/IEEE 29148:2018	70
12. Correcciones	72
12.1. Respuesta a la revisión del docente-director sobre la versión 1.0.0	72
12.2. Defectos de trazabilidad corregidos en la versión 1.0.0	74
12.3. Estados declarados que ya no correspondían	74
12.4. Cobertura: de 16 requisitos a 90	74
12.5. Secciones estructurales incorporadas	75
12.6. Lenguaje y forma	75
13. Deuda declarada y plan de cierre	75
13.1. Orden de trabajo propuesto	75
13.2. Origen de los requisitos sin historia de usuario	76
13.3. Defectos funcionales menores declarados	76
14. Anexo: <i>checklist</i> INCOSE	77
15. Anexo: técnicas de elicitación aplicadas	77
16. Página de aprobación	78

1. Identificación y control del documento

1.1. Historial de versiones

Versión	Fecha	Autor	Cambios
1.0.0	2026-09-08	J. P. Álava Alvarado	Primera versión de esta especificación. Corpus de 64 requisitos funcionales y 26 no funcionales, redactados y verificados contra el código real de la etiqueta v1.0.1 . Incorpora la plantilla completa por requisito y las cinco secciones estructurales que la norma exige. Entregada a revisión del docente-director.
1.0.1	2026-09-11	J. P. Álava Alvarado	Incorpora la revisión del docente-director sobre la v1.0.0 (8 observaciones de modificación y 4 de adición). El corpus no cambia: cambian las fuentes declaradas, la redacción de la cláusula de verificación, la portada y la trazabilidad de las cifras. La respuesta punto por punto está en la sección 12.1 .

Cuadro 1: Historial de versiones del SRS. La bitácora completa de cambios de requisitos vive en `docs/requisitos/CH ANGELOG-REQ.md`.

Documentos a los que reemplaza. Esta especificación sustituye a los dos borradores de requisitos anteriores del proyecto, que quedan archivados en `docs/requisitos/historico/` y no deben citarse como especificación vigente: el borrador del 2026-07-30 (5 historias de usuario, sin casos de uso) y el del 2026-08-17 (12 historias y 12 casos de uso, con un resumen de 12 requisitos funcionales y 4 no funcionales). Ninguno de los dos describía más de una novena parte de las rutas que el sistema expone hoy; las correcciones concretas que se les hicieron están en la sección [12](#).

1.2. Alcance de esta versión y punto de corte

Nota de alcance sobre la autoría. Esta especificación fue elaborada de forma individual por Jean Pierre Álava Alvarado. El sistema que describe se construyó en el marco de un trabajo de equipo y el repositorio mantiene el historial completo de todas las personas que contribuyeron código; lo que esta versión declara es la autoría del *documento de requisitos*, no la del software. Se hace constar aquí, y no en la portada, porque la portada identifica a quien responde por el documento y nada más.

Todo enunciado de estado, cifra y referencia a código de este documento se verificó **contra el árbol de archivos de la etiqueta v1.0.1** (*commit* `9d7abbd`, 2026-09-05) y se contrastó con la rama principal al *commit* `3e7069c` (2026-09-09), que es el punto sobre el que se emitió la revisión

del docente-director. Las cifras que dependen de una medición traen la fecha de esa medición dentro del propio requisito: una cifra sin fecha envejece sola y deja de ser verificable.

1.3. Autoridad de cada artefacto

Este documento y la matriz de trazabilidad no compiten: cada uno es fuente de verdad de algo distinto, y esa separación es lo que evita que se desincronicen sin que nadie lo note.

Artefacto	Es fuente de verdad de
Este SRS	El enunciado normativo, el <i>rationale</i> , la prioridad MoSCoW, el criterio de aceptación y el método de verificación de cada requisito.
<code>docs/trazabilidad/matriz.csv</code>	El estado de verificación, el endpoint, el módulo, la clase de prueba y la evidencia empírica de cada requisito.
<code>scripts/validate-traceability.sh</code>	La coherencia entre ambos y con el disco. Ninguna versión se publica si el validador no termina con código 0.

2. Introducción

2.1. Propósito

Este documento define los requisitos funcionales y no funcionales del Sistema de Gestión de Pre-Sustentaciones UTEQ conforme al estándar ISO/IEC/IEEE 29148:2018. Sirve como contrato técnico entre la coordinación académica, los docentes, los estudiantes y quien desarrolla el sistema, y como base de verificación: cada requisito declara cómo se comprueba y en qué estado está.

2.2. Alcance del sistema

El sistema automatiza el ciclo completo de pre-sustentación de trabajos de titulación: provisión de cuentas y control de acceso por permisos; registro y revisión de la solicitud; asignación de tutor y acompañamiento en tres fases de tutoría con entrega de correcciones; carga del anteproyecto en PDF con verificación de integridad SHA-256; conformación del tribunal; programación del cronograma de defensa con detección de conflictos de sala y de jurado; evaluación por rúbrica y cálculo de la nota final ponderada; emisión del acta en PDF y su firma digital multi-actor; notificaciones; reportes de gestión; un centro de orientación de titulación; una bitácora de auditoría; y la gestión de respaldos y recuperación de la base de datos.

Fuera de alcance declarado: matrícula y expediente académico institucional, pago de aranceles, firma electrónica con validez jurídica ante entidad certificadora, y la sustentación final de grado (este sistema cubre la *pre*-sustentación).

2.3. Definiciones, acrónimos y abreviaturas

- **SRS:** *Software Requirements Specification* (ISO/IEC/IEEE 29148:2018).
- **UTEQ:** Universidad Técnica Estatal de Quevedo.
- **RF / RNF:** Requisito Funcional / Requisito No Funcional.

- **HU / CU:** Historia de Usuario (Connextra) / Caso de Uso (plantilla Cockburn).
- **MoSCoW:** priorización *Must* / *Should* / *Could* / *Won't*.
- **JWT:** *JSON Web Token*. **jti:** identificador único del token.
- **SP:** procedimiento almacenado PL/pgSQL.
- **IDOR:** *Insecure Direct Object Reference*, acceso a un recurso ajeno por manipulación de su identificador.
- **RPO / RTO:** objetivo de punto de recuperación / objetivo de tiempo de recuperación.
- **Titular:** persona a la que pertenecen los datos personales tratados.
- **Tribunal:** conjunto de tres docentes con roles **PRESIDENTE**, **VOCAL_1** y **VOCAL_2** asignados a una solicitud.

2.4. Convención de redacción normativa

Esta convención es de aplicación obligatoria a todo requisito de este documento y a todo requisito que se agregue en el futuro.

1. El verbo vinculante es **«debe»**. Todo enunciado que use «debe» expresa una obligación exigible y verificable.
2. **No se usa «debería»** en el enunciado de ningún requisito. En la convención de la norma «debería» expresa una recomendación no vinculante y, por lo tanto, no enuncia un requisito. Una recomendación va en el *rationale* o en una nota, nunca en el enunciado.
3. **No se usa el presente indicativo descriptivo** («el sistema usa PostgreSQL») para enunciar un requisito: eso describe lo construido en vez de especificar lo exigido. Las tecnologías impuestas se declaran como **restricciones de diseño** (sección 3.3), no como requisitos.
4. Todo requisito es **singular**: enuncia una sola capacidad. Cuando por cohesión se agrupan varias capacidades bajo un mismo identificador, el requisito trae **un criterio de aceptación por cada capacidad agrupada**; si sus estados pueden diferir, el requisito se divide en sufijos (a, b, c).
5. El criterio de aceptación se expresa como **comportamiento observable por el cliente** (código HTTP y contenido de la respuesta), nunca como detalle de implementación interna. El nombre de la excepción o de la clase Java pertenece a la matriz de trazabilidad, no al criterio.
6. El requisito **no cita rutas de archivo ni nombres de clase**: son lo primero que envejece con un renombrado de paquetes. El requisito cita el **endpoint**, que es estable; la ruta y la clase viven en la matriz, donde el validador las comprueba contra el disco.

2.5. Vocabulario cerrado de estado del requisito

El campo **Estado** de cada requisito admite exactamente estos cuatro valores y ningún otro. Cualquier matiz («implementado pero sin resolución ética», «medido el 18-08») va en el campo **Nota**, nunca en el campo Estado; de lo contrario la matriz deja de poder filtrarse y contarse, y el vocabulario se degrada en cada ampliación.

Valor	Significado técnico
Verificado	La capacidad está construida y existe una prueba automatizada o una evidencia empírica archivada y fechada que comprueba su criterio de aceptación.
Implementado	La capacidad está construida y responde en el endpoint declarado, pero su criterio de aceptación aún no tiene prueba ni evidencia archivada.
Planificado	La capacidad no está construida . Existe el requisito, no la funcionalidad.
No cumplido	La capacidad está construida pero no alcanza el umbral que su propio criterio de aceptación exige. Es distinto de «pendiente de evidencia»: aquí sí se midió, y el resultado no cumple.

Regla de lectura: ningún requisito marcado **Planificado** o **No cumplido** debe interpretarse como funcionalidad entregada y conforme. Un requisito *Must* en estado **Planificado** o **No cumplido** es deuda declarada, y aparece como tal en la sección 10.

2.6. Métodos de verificación

Todo requisito declara su método de verificación con este vocabulario cerrado de cuatro valores. Declarar el método, y no solo decir «se probó», es lo que permite saber si un requisito que no se puede cubrir con una prueba unitaria está o no verificado.

Método	Cuándo se usa y qué evidencia produce
Prueba	Prueba automatizada (unitaria o de integración) que se ejecuta en CI y falla si el criterio deja de cumplirse. Evidencia: la clase de prueba, declarada en la matriz.
Demostración	Ejecución observada del sistema desplegado sobre la topología real. Evidencia: la transcripción o captura archivada en docs/mediciones/ o docs/evidencias/, con fecha.
Análisis	Medición instrumentada o cálculo sobre datos crudos archivados (k6, JaCoCo, Lighthouse, SUS, ZAP). Evidencia: el archivo crudo y el comando que lo generó, mapeados en docs/mediciones/DATA-PROVENANCE.md.
Inspección	Revisión de código, configuración o migración cuando el criterio es estructural y no se puede ejercitar en tiempo de ejecución. Evidencia: el artefacto inspeccionado y la fecha de la inspección.

2.7. Referencias

- ISO/IEC/IEEE 29148:2018 — *Systems and software engineering — Life cycle processes — Requirements engineering*.
- INCOSE *Guide for Writing Requirements*, v4.
- OWASP *Top 10* (2021) — referencia de los requisitos de seguridad.
- WCAG 2.1 nivel AA — referencia del requisito de accesibilidad.
- Ley Orgánica de Protección de Datos Personales del Ecuador (LOPD).
- Brooke, J. (1996). *SUS: A quick and dirty usability scale* — instrumento de RNF-22.

- Decisiones de arquitectura del proyecto: docs/adr/ADR-001 a ADR-007.

3. Descripción general

3.1. Perspectiva del producto

Solución web de arquitectura en N capas: cliente Angular (SPA) servido por nginx como proxy inverso, servicio de aplicación Spring Boot que expone una API REST, base de datos PostgreSQL con esquema **presus** versionado por migraciones Flyway y una parte de la lógica de negocio resuelta en procedimientos almacenados PL/pgSQL, y Redis como caché, almacén de *refresh tokens*, lista de revocación de tokens de acceso y contador del límite de tasa. Todos los componentes se orquestan con Docker Compose.

Tamaño real del sistema en el punto de corte: 31 controladores REST *de producción* —49 si se cuentan también las 18 clases de prueba de controlador, que no exponen ninguna ruta— con 207 combinaciones de método y ruta, 10 rutinas SQL (8 procedimientos y 2 funciones de auditoría), 30 migraciones Flyway y 559 pruebas automatizadas. Estas cifras están contadas sobre la etiqueta v1.0.1 y se recuentan en cada versión de este documento; no se dejan sin fecha.

3.2. Actores del sistema

Actor	Descripción	Responsabilidad en el proceso
Estudiante	Postulante a titulación.	Registra su solicitud, entrega correcciones en las tres fases de tutoría, carga el anteproyecto, consulta su ruta de progreso y su acta.
Docente	Personal académico.	Puede actuar como tutor, como miembro del tribunal, o ambos en solicitudes distintas. Nunca ambos en la misma solicitud.
Tutor	Rol funcional de un Docente sobre una solicitud.	Abre y aprueba las fases de tutoría, revisa el anteproyecto y firma el acta con rol TUTOR.
Miembro del tribunal	Rol funcional de un Docente sobre una solicitud (PRESIDENTE, VOCAL_1, VOCAL_2).	Registra su evaluación por criterio de rúbrica y firma el acta con su rol.
Coordinador	Gestor académico de la carrera.	Revisa y aprueba solicitudes, asigna tutor y tribunal, programa el cronograma, gestiona salas y rúbricas, y consulta reportes.
Administrador	Administrador del sistema.	Gestiona usuarios, roles y permisos, catálogos académicos, la bitácora de auditoría y los respaldos.

Cuadro 2: Actores. *Tutor* y *miembro del tribunal* no son roles de cuenta sino roles funcionales asignados por solicitud: un mismo Docente los ejerce o no según la solicitud. Esta distinción es la que explica por qué un permiso no basta para firmar un acta (ver RF-37).

3.3. Restricciones de diseño

Estas son imposiciones sobre la solución, no requisitos del sistema. Se declaran aparte porque la norma distingue requisito de restricción, y porque enunciarlas como requisitos («el sistema usa PostgreSQL») describiría lo construido en vez de especificar lo exigido.

ID	Restricción y origen
RD-01	La persistencia debe ser PostgreSQL 15 o superior, con el esquema versionado por migraciones Flyway y <code>ddl-auto=validate</code> . Origen: ADR-006 (estrategia híbrida ORM + procedimientos almacenados).
RD-02	El cliente debe ser una SPA Angular servida por nginx; el navegador nunca consume servicios de terceros directamente. Origen: ADR-003.
RD-03	La autenticación debe ser sin estado de sesión en el servidor, basada en JWT. Origen: ADR-002.
RD-04	El despliegue debe ser reproducible con Docker Compose desde una clonación limpia. Origen: ADR-007 y criterio de reproducibilidad de la asignatura.
RD-05	La autorización debe resolverse contra un catálogo de permisos almacenado en base de datos, no contra roles fijos en código. Origen: ADR-005.

3.4. Supuestos y dependencias

1. Las cuentas las provisiona el Administrador. **No existe autorregistro público**, y esto es una decisión deliberada, no una omisión: el sistema trata expedientes académicos nominales.
2. El correo institucional es el identificador único de la cuenta.
3. El sistema depende de PostgreSQL y de Redis. El comportamiento exigido ante la caída de Redis se especifica en RNF-04 y **no** se deja como nota de riesgo: una política de degradación es una decisión de seguridad y merece un requisito.
4. El único servicio externo consumido es el directorio de universidades descrito en la sección 4.2. **No se envía ningún dato personal a terceros**, y RNF-20 lo convierte en obligación exigible para que ninguna refactorización futura pueda cambiarlo sin romper un requisito.
5. El envío de correo saliente está previsto pero desactivado por configuración (`app.mail.enabled`). Mientras esté desactivado, las notificaciones son exclusivamente internas (RF-41).

4. Interfaces externas

La norma distingue la interfaz que el sistema *expone* de la que *consume*. Se separan aquí porque son contratos distintos: en la expuesta el sistema fija las reglas, y en la consumida las sufre, de modo que cada interfaz consumida necesita además un comportamiento declarado ante la indisponibilidad del otro extremo.

4.1. Interfaces expuestas

Interfaz	Protocolo / formato	Autenticación	Contrato
API REST	HTTP/1.1, JSON UTF-8, sobre estructura ResponseWrapper {success, message, data}	<i>Bearer</i> en cabecera <i>Authorization</i> , o <i>cookie</i> <i>jwtToken</i> <i>HttpOnly</i>	207 combinaciones método+ruta bajo <code>/api/</code> y <code>/api/v1/</code> ; contrato publicado en OpenAPI 3.0 en <code>/v3/api-docs</code> y <code>/swagger-ui/index.html</code> .
Sonda de salud	HTTP, JSON	Ninguna (pública)	<code>/actuator/health</code> con detalle por componente (<code>db</code> , <code>redis</code> , <code>diskSpace</code>); es lo que permite comprobar que las migraciones se aplicaron sin autenticarse.
Proxy inverso	HTTP/HTTPS	N/A	nginx sirve la SPA y reenvía <code>/api/</code> al servicio de aplicación, con las mismas cabeceras de seguridad que exige RNF-10.

4.2. Interfaces consumidas

Proveedor	Protocolo	Autenticación	Comportamiento exigido ante indisponibilidad
Directorio de universidades (<i>Hipo Labs</i>)	HTTP, JSON, GET/ <code>search?country=Ecuador</code>	Ninguna	Tiempo de espera de 5 s en conexión, lectura y escritura; 3 reintentos con retroceso exponencial desde 1 s; agotados, respuesta de reserva local. Nunca propaga el fallo al cliente (RF-45).
PostgreSQL	TCP, JDBC	Usuario y contraseña por variable de entorno	Indisponibilidad total del servicio. La aplicación no debe arrancar si las migraciones no se aplican.
Redis	TCP (RESP)	Contraseña opcional por variable de entorno	Degradación explícita y fail-closed en la verificación de revocación de tokens y en el límite de tasa (RNF-04).
SMTP saliente	SMTP/TLS	Usuario y contraseña por variable de entorno	Desactivado por defecto (<code>app.mail.enabled=false</code>). Con el envío activo, un fallo del proveedor no debe impedir que la notificación interna se registre (RF-41).

Nota deliberada sobre proveedores de inteligencia artificial: el asistente virtual (RF-44) y la generación de ideas de tema (RF-47) se resuelven **íntegramente dentro del sistema**, sin consumir ningún proveedor externo de modelo de lenguaje. Ningún dato personal sale hacia un tercero. RNF-20 convierte esa propiedad en una obligación verificable, porque hoy vive solo en el código y nada impediría que una refactorización futura empezara a enviar datos.

5. Catálogo de estados del dominio y transiciones

Los criterios de aceptación de la sección 7 usan nombres de estado. Esta sección declara, para cada entidad con ciclo de vida, el **conjunto cerrado** de sus valores admisibles y las transiciones válidas con el actor o evento que las dispara. Sin esta tabla los criterios de aceptación se apoyan en vocabulario no definido.

5.1. Solicitud de pre-sustentación

Estado	Significado	Transición de salida (disparador)
CREADA	Registrada, aún no enviada.	→ ENVIADA (Estudiante envía). No es suspendible.
ENVIADA	En revisión de la coordinación.	→ APROBADA / RECHAZADA (Coordinador).
APROBADA	Aceptada; habilita la asignación de tutor.	→ TUTORIA (asignación de tutor).
TUTORIA	Acompañamiento en curso.	→ EVALUACION (asignación de tribunal, que exige tutoría completada).
EVALUACION	Tribunal conformado y defensa programable.	→ CALIFICADA (registro de la nota final).
CALIFICADA	Nota final registrada; habilita el acta.	→ COMPLETADA (última firma del acta).
COMPLETADA	Proceso cerrado.	Terminal.
RECHAZADA	Rechazada por la coordinación.	Terminal. No es suspendible.
SUSPENDIDA	Detenida por decisión académica, con motivo obligatorio.	Terminal en esta versión. No es suspendible de nuevo.

Cuadro 3: Estados de la solicitud. Cualquier estado distinto de **CREADA**, **RECHAZADA** y **SUSPENDIDA** admite la transición a **SUSPENDIDA** (RF-16).

5.2. Acta de pre-sustentación

Estado	Significado	Transiciones válidas de salida
GENERADA	Acta emitida en PDF.	REVISADA, OBSERVADA, ANULADA.
REVISADA	Revisada académicamente.	FINALIZADA, OBSERVADA, ANULADA.
OBSERVADA	Con observaciones; exige motivo.	REVISADA, GENERADA, ANULADA.
FINALIZADA	Cerrada. Se alcanza también de forma automática con la cuarta firma.	ANULADA.
ANULADA	Anulada; exige motivo.	Terminal.

Cuadro 4: Estados del acta. OBSERVADA y ANULADA exigen motivo. La transición a ANULADA desde cualquier estado está reservada al Administrador (RF-39).

5.3. Tutoría, fase de tutoría y demás entidades

Entidad	Conjunto cerrado de estados	Disparador del cambio
Tutoría (tutores)	ACTIVO, COMPLETADA	COMPLETADA cuando las 3 fases quedan aprobadas (RF-26).
Fase de tutoría	PENDIENTE_TUTOR, PENDIENTE_ESTUDIANTE, APROBADA	El tutor abre y aprueba; el estudiante entrega.
Mensaje de fase	OBSERVACION, RESPUESTA, APROBACION	Tipo fijado por el emisor y la acción.
Anteproyecto (estados_proceso)	PENDIENTE, EN_PROCESO, APROBADO, OBSERVADO, RECHAZADO	Revisión del tutor (RF-21).
Cronograma	PROGRAMADO	Único estado en uso en esta versión.
Resultado de evaluación	APROBADO ($\geq 7,0$), REPROBADO ($< 7,0$)	Calculado, no editable (RF-34).
Estudiante (académico)	ACTIVO, EGRESADO, GRADUADO, RETIRADO, SUSPENDIDO	Gestión de estudiantes (RF-54).
Cuenta de usuario	activo verdadero / falso	Activación y desactivación (RF-09).

Hallazgo declarado (2026-09-09). Los nueve estados de la solicitud y el único estado del cronograma **no están sembrados por ninguna migración**: se crean bajo demanda la primera vez que el proceso los necesita. La consecuencia es que en una base recién migrada el catálogo está vacío, y tanto el identificador como el campo **orden** de cada estado dependen del orden en que se ejecuten los casos de uso. RF-13 declara el conjunto cerrado y RNF-25 exige que la siembra sea determinista; hasta que esa siembra exista, el catálogo de estados no es reproducible entre dos despliegues. Se declara aquí en vez de presentar la tabla como si fuera un catálogo sembrado.

6. Matriz de permisos por rol y operación

Con 31 controladores y 207 rutas, los permisos ya no se pueden auditar leyendo requisito por requisito: hace falta una tabla normativa. Esta sección la fija. Es la única forma de decidir si una

asimetría de acceso es una decisión de negocio o un defecto, y es lo que permite detectar un permiso que se otorgó sin querer.

6.1. Modelo de autorización

El sistema define **4 roles de cuenta** (ADMIN, COORDINADOR, DOCENTE, ESTUDIANTE) y **29 permisos** en catálogo de base de datos. La autorización se resuelve por permiso, no por rol, y la asignación permiso $\rightarrow$ rol es editable en caliente (RF-12). Sobre ese control se aplican, cuando corresponde, dos comprobaciones adicionales que el permiso por sí solo no cubre:

- **Propiedad del recurso:** el titular solo accede a lo suyo (RNF-13).
- **Rol funcional en la solicitud:** tener ACTA_FIRMAR no habilita a firmar cualquier acta; hay que ser además el tutor o el miembro del tribunal de esa solicitud (RF-37).

6.2. Asignación normativa de permisos

Permiso	ADMIN	COORD.	DOCENTE	ESTUD.
<i>Administración</i>				
USUARIOS_GESTIONAR	Sí	—	—	—
ROLES_PERMISOS_GESTIONAR	Sí	—	—	—
AUDITORIA_VER	Sí	—	—	—
BACKUPS_GESTIONAR	Sí	—	—	—
CARRERAS_GESTIONAR	Sí	—	—	—
ESTUDIANTES_GESTIONAR	Sí	Sí	—	—
NOTIFICACIONES_GLOBAL_VER	Sí	—	—	—
NOTIFICACIONES_ENVIAR	Sí	Sí	—	—
<i>Solicitudes y proceso</i>				
SOLICITUDES_REVISAR	Sí	Sí	Sí	—
SOLICITUDES_SUSPENDER	Sí	Sí	—	—
TRIBUNAL_TUTOR_ASIGNAR	Sí	Sí	—	—
CRONOGRAMA_GESTIONAR	Sí	Sí	—	—
SALA_GESTIONAR	Sí	Sí	—	—
<i>Tutoría y anteproyecto</i>				
ANTEPROYECTO_REVISAR	Sí	Sí	Sí	—
TUTORIA_GESTIONAR	Sí	Sí	Sí	—
TUTORIA_AVANCE_ESTUDIANTE	Sí	Sí	—	Sí
<i>Evaluación</i>				
RUBRICA_GESTIONAR	Sí	Sí	—	—
EVALUACION_RUBRICA_REGISTRAR	Sí	Sí	Sí	—
EVALUACION_CALIFICAR	Sí	Sí	—	—

Permiso	ADMIN	COORD.	DOCENTE	ESTUD.
<i>Actas</i>				
ACTA_GENERAR	Sí	Sí	—	—
ACTA_FIRMAR	Sí	Sí	Sí	—
ACTAS_VER	Sí	Sí	—	—
ACTAS_VER_PROPIAS	Sí	—	Sí	—
ACTA_HISTORIAL_VER	Sí	Sí	Sí	—
ACTA_ESTADO_CAMBIAR	Sí	Sí	—	—
ACTAS_GESTIONAR	Sí	—	—	—
<i>Reportes y orientación</i>				
REPORTES_VER	Sí	Sí	—	—
ORIENTACION_TEMAS_VER	Sí	Sí	Sí	Sí
ORIENTACION_CATALOGO_GESTIONAR	Sí	Sí	—	—

Cuadro 5: Asignación normativa permiso × rol. «Sí» significa que el rol posee el permiso en la configuración inicial sembrada; «—» que no lo posee. La asignación es editable en caliente por RF-12, de modo que esta tabla especifica el **estado inicial exigido**, no una constante inmutable.

6.3. Acceso que no depende del catálogo de permisos

Tres capacidades se autorizan por rol de cuenta o por simple autenticación, no por permiso. Se declaran aparte para que la tabla anterior no se lea como la superficie completa de autorización:

Capacidad	Control	Requisito
Ruta de progreso de titulación	Rol ESTUDIANTE	RF-51
Temas guardados	Rol ESTUDIANTE	RF-48
Consulta de catálogos de apoyo, docentes, asistente virtual, universidades, estado en tiempo real, notificaciones propias, perfil propio	Usuario autenticado	RF-53, RF-55, RF-44, RF-45, RF-43, RF-41, RF-10

6.4. Asimetrías declaradas

Tres asimetrías de la tabla anterior son intencionales y se explican aquí para que una revisión futura no las tome por defectos, y una cuarta es una desviación real que queda como deuda:

1. El Coordinador no gestiona catálogos académicos (CARRERAS_GESTIONAR es exclusivo del

Administrador) aunque sí gestiona estudiantes. Es deliberado: facultades, carreras, modalidades y períodos son datos maestros institucionales.

2. **El Coordinador no accede a la bitácora de auditoría** (`AUDITORIA_VER`) ni a los respaldos. La auditoría debe poder registrar acciones del Coordinador sin que él pueda consultarlas.
3. **El Administrador posee `ACTAS_VER_PROPIAS`** pese a no ser docente. Es consecuencia de otorgarle el conjunto completo; carece de efecto porque el filtro por propiedad no le devuelve actas.
4. **Deuda declarada:** el Coordinador posee `TUTORIA_AVANCE_ESTUDIANTE`, `ACTA_FIRMAR`, `ANTEPROYECTO_REVISAR` y `TUTORIA_GESTIONAR` por herencia de la regla «todos los permisos menos tres» con la que se sembró el catálogo inicial, no por una decisión sobre cada uno. No hay riesgo de acceso indebido porque las comprobaciones de rol funcional de RF-37, RF-21 y RF-23 rechazan a quien no es el tutor o el jurado de esa solicitud; pero la asignación no refleja una decisión y debe revisarse permiso por permiso.

7. Requisitos funcionales

Cada requisito se especifica con la plantilla completa que exige la sección 2.4: enunciado normativo, prioridad MoSCoW, fuente, endpoint, *rationale*, criterio de aceptación observable, método de verificación (sección 2.6) y estado del vocabulario cerrado (sección 2.5). Los endpoints se citan tal como los expone el servicio en la etiqueta `v1.0.1`; la ruta de archivo y la clase de prueba viven en la matriz de trazabilidad, no aquí.

7.1. Autenticación y gestión de la sesión

RF-01 Autenticación con credenciales institucionales

Enunciado: El sistema debe autenticar a un usuario a partir de su correo institucional y su contraseña, y emitir un token de acceso y un token de renovación asociados a esa sesión.

Prioridad: Must

Fuente: HU-01, CU-01, ADR-002

Endpoint: `POST/api/v1/auth/login`

Rationale: Es la puerta de entrada de todo el sistema: ningún otro requisito es alcanzable sin ella, y su diseño determina qué puede hacer un atacante que capture una credencial.

Criterio de aceptación:

- Con credenciales válidas responde 200 y devuelve el token de acceso, el identificador, el correo, el nombre y el rol del usuario.
- El token de acceso lleva los siete atributos `jti`, `iss`, `sub`, `aud`, `iat`, `nbfi` y `exp`.
- Con contraseña incorrecta responde 401. Con un correo no registrado responde **también** 401, con el mismo cuerpo: la respuesta no debe permitir distinguir un correo existente de uno inexistente.

- Nunca devuelve la contraseña ni su representación almacenada en el cuerpo de la respuesta.
- Superado el límite de RNF-09 responde 429.

Método de verificación: Prueba

Estado: **Verificado**

Depende de: RNF-05, RNF-07, RNF-09

RF-02 Renovación del token de acceso con rotación del token de renovación

Enunciado: El sistema debe emitir un nuevo token de acceso a partir de un token de renovación válido, invalidando en el mismo acto el token de renovación empleado y emitiendo uno nuevo.

Prioridad: Must

Fuente: ADR-002; OWASP A07 (fallos de identificación y autenticación)

Endpoint: POST/api/v1/auth/refresh

Rationale: Sin rotación, un token de renovación robado sirve indefinidamente durante toda su vida útil. Con rotación, su reutilización se vuelve detectable, que es lo que convierte el robo en un evento observable en vez de silencioso.

Criterio de aceptación:

- Con un token de renovación vigente responde 200 con un token de acceso nuevo y un token de renovación nuevo.
- El token de renovación empleado deja de ser válido de inmediato: un segundo uso responde 401.
- Si el token presentado es uno ya utilizado, el sistema debe tratarlo como **reutilización** y responder 401 **revocando además todas las sesiones activas de ese usuario**, no solo rechazando la petición.
- Sin token de renovación en la petición responde 400.

Método de verificación: Prueba

Estado: **Verificado**

RF-03 Cierre de sesión con revocación del token de acceso

Enunciado: El sistema debe invalidar, al cerrar sesión, tanto el token de renovación de esa sesión como el token de acceso presentado, de modo que este último deje de aceptarse aunque no haya expirado.

Prioridad: Must

Fuente: ADR-002

Endpoint: POST/api/v1/auth/logout

Rationale: Un token de acceso sin estado es válido hasta su expiración por construcción. Sin una lista de revocación consultada en cada petición, «cerrar sesión» sería una acción puramente cosmética en el cliente.

Criterio de aceptación:

- Responde 200 y limpia las *cookies* de sesión del cliente.
- Una petición posterior a cualquier endpoint protegido con **ese mismo** token de acceso responde 401, aun estando dentro de su ventana de validez.
- La entrada de revocación debe expirar por sí sola al vencer el token, sin crecimiento ilimitado del almacén.

Método de verificación: Prueba

Estado: **Verificado**

Depende de: RNF-04 (la revocación se apoya en Redis y su política de degradación es la que decide qué pasa si el almacén no responde)

RF-04 Provisión de cuentas por el Administrador

Enunciado: El sistema debe permitir únicamente al Administrador crear cuentas de usuario, aceptando exclusivamente nombre, apellido, correo, contraseña y rol.

Prioridad: Must

Fuente: HU-11, CU-11; hallazgo de auditoría OWASP A01 del 2026-09-04

Endpoints: POST/api/v1/auth/register, POST/api/usuarios

Rationale: El sistema trata expedientes académicos nominales, así que el alta no puede ser pública. Además, aceptar la entidad completa del cliente permitiría fijar por asignación masiva campos que no le corresponden (identificador, estado activo, rol interno, fecha de creación).

Criterio de aceptación:

- Sin el permiso USUARIOS_GESTIONAR responde 403.
- Ningún campo del cuerpo distinto de los cinco admitidos debe alterar el registro creado, aunque se envíe.
- Con un correo ya registrado responde 400 sin crear el usuario.
- El rol declarado y el rol interno del usuario quedan siempre resueltos al mismo valor; no es posible crear una cuenta con ambos desincronizados.
- La contraseña se almacena conforme a RNF-05 y nunca se devuelve.

Método de verificación: Prueba

Estado: **Verificado**

Depende de: RNF-06

RF-05 Recuperación de la contraseña olvidada

Enunciado: El sistema debe permitir al titular de una cuenta solicitar la recuperación de su contraseña indicando su correo institucional, y restablecerla mediante un elemento de un solo uso con vigencia limitada enviado a ese correo.

Prioridad: Must

Fuente: OWASP A07 (recuperación de credenciales). Carencia detectada al contrastar el asistente virtual (RF-44), que ya ofrece esta capacidad al usuario, con los endpoints realmente expuestos por el módulo de autenticación.

Endpoints: POST/api/v1/auth/recuperar, POST/api/v1/auth/restablecer

Rationale: Es la única carencia del corpus que exige programar y no solo redactar. Como las cuentas las crea exclusivamente el Administrador (RF-04) y la actualización de usuario **no modifica la contraseña**, hoy un usuario que la olvida no tiene ninguna vía de recuperación dentro del sistema: ni propia, ni administrativa. La única salida es una intervención directa sobre la base de datos, que no está especificada, no deja traza de autorización y no es auditable.

Criterio de aceptación:

- La solicitud responde 200 con el mismo cuerpo tanto si el correo está registrado como si no: la respuesta no debe permitir enumerar cuentas.
- El elemento de un solo uso caduca a los 30 minutos y no puede emplearse dos veces.
- Al restablecerse la contraseña se aplican las exigencias de RNF-06 y **se revocan todas las sesiones activas** del titular.
- El número de solicitudes por cuenta y por ventana de tiempo está limitado, para que el endpoint no sea un vector de abuso de correo.

Método de verificación: Prueba

Estado: **Implementado**

Nota: Construido en la fase 6 (2026-09-11), con una decisión honesta y declarada sobre el obstáculo real: `EmailService` existe pero `app.mail.enabled=false` por omisión, así que no había forma de entregar el elemento de un solo uso sin activar SMTP de verdad. Se optó deliberadamente por **no** declarar el requisito **Verificado** sin haber comprobado nunca que el correo llega – la salida deshonesto que el propio encargo de esta fase prohíbe. En su lugar: el flujo completo se construyó y se probó de punta a punta con el envío apagado (`PasswordRecoveryServiceTest`, 6 casos: token con TTL de 30 min, un solo uso, aplica RNF-06, revoca *todas* las sesiones sin excepción a diferencia de RF-06; más los casos de `AuthControllerIntegrationTest` sobre el mismo cuerpo/código de respuesta exista o no la cuenta, y el límite de tasa con su fail-closed de RNF-04), y se declara **Implementado**, no **Verificado**: la entrega real del correo por SMTP nunca se verificó contra un servidor real. Activarla y comprobarla es lo que falta para el cierre completo.

RF-06 Cambio de la contraseña propia

Enunciado: El sistema debe permitir a un usuario autenticado cambiar su propia contraseña presentando la contraseña vigente.

Prioridad: Must

Fuente: OWASP A07 y NIST SP 800-63B: el titular debe poder cambiar su propia credencial. Carencia detectada al contrastar RF-04 y RF-08 con los endpoints reales.

Endpoint: PATCH/api/v1/auth/usuarios/{id}/password

Rationale: Las contraseñas iniciales las fija el Administrador (RF-04), de modo que sin esta capacidad el usuario nunca controla su propia credencial y una contraseña inicial conocida por un tercero permanece válida indefinidamente.

Criterio de aceptación:

- Con la contraseña vigente correcta responde 200; con la incorrecta, 401, sin cambiar nada.
- La contraseña nueva cumple RNF-06 y no puede ser igual a la vigente.
- El cambio revoca todas las sesiones activas del titular salvo aquella desde la que se realiza.
- Solo el titular cambia su propia contraseña: sobre otro usuario responde 403, incluso si quien lo intenta es Administrador (mismo patrón que RF-10 con el perfil).
- Se almacena conforme a RNF-05 (BCrypt, factor de coste ≥ 10) y no se devuelve nunca, ni la vigente ni la nueva, en ninguna respuesta.

Método de verificación: Prueba

Estado: Verificado

RF-07 Consulta de los permisos efectivos propios

Enunciado: El sistema debe devolver al usuario autenticado el conjunto de códigos de permiso que su rol tiene concedidos en ese momento.

Prioridad: Should

Fuente: ADR-005

Endpoint: GET/api/me/permisos

Rationale: Permite al cliente ocultar lo que el usuario no puede ejecutar sin duplicar el mapa de permisos en el frontend. La decisión de autorización sigue siendo del servidor (RNF-12): esto es presentación, no control de acceso.

Criterio de aceptación:

- Responde 200 con la lista de códigos de permiso del usuario en sesión.
- El resultado refleja los cambios de RF-12 sin necesidad de volver a iniciar sesión.
- Sin autenticación responde 401.
- Devuelve exclusivamente los permisos del usuario en sesión, nunca los de otro.

Método de verificación: Prueba

Estado: Implementado

7.2. Identidades y autorización

RF-08 Gestión de usuarios

Enunciado: El sistema debe permitir al Administrador consultar, crear, modificar y eliminar usuarios, y consultarlos de forma paginada, por correo y filtrados por estado activo.

Prioridad: Must

Fuente: HU-11, CU-11

Endpoints: GET/api/usuarios, GET/api/usuarios/paginado, GET/api/usuarios/{id}, GET/api/usuarios/email/{email}, GET/api/usuarios/activos, PUT/api/usuarios/{id}, DELETE/api/usuarios/{id}

Rationale: Es el requisito que sostiene la identidad de todos los demás: sin gestión de usuarios no hay a quién asignar tutor, tribunal ni acta.

Criterio de aceptación:

- Toda operación de esta capacidad sin el permiso `USUARIOS_GESTIONAR` responde 403.
- Ninguna respuesta incluye la contraseña almacenada, en ninguna de las operaciones.
- El borrado de un usuario con historial académico asociado se rechaza con 400 en vez de dejar registros huérfanos; la vía prevista para ese caso es RF-09.
- La modificación de un usuario **no altera su contraseña**.

Método de verificación: Prueba

Estado: **Verificado**

Nota: El último criterio documenta el comportamiento real y es también el que hace inevitable RF-05: hoy nadie, ni siquiera el Administrador, puede restablecer una contraseña desde el sistema.

RF-09 Activación y desactivación de cuentas

Enunciado: El sistema debe permitir al Administrador desactivar y reactivar una cuenta sin eliminarla, y una cuenta desactivada no debe poder autenticarse.

Prioridad: Should

Fuente: HU-11

Endpoints: PATCH/api/usuarios/{id}/activar, PATCH/api/usuarios/{id}/desactivar

Rationale: Es la baja correcta cuando el usuario ya tiene historial académico: preserva la trazabilidad de sus actas y evaluaciones, cosa que el borrado destruiría.

Criterio de aceptación:

- Responde 200 y el estado activo del usuario queda en el valor solicitado.
- Un intento de autenticación de una cuenta desactivada responde 401.
- Sin el permiso `USUARIOS_GESTIONAR` responde 403.

- El cambio queda registrado en la bitácora de auditoría con el actor que lo realizó (RNF-18).

Método de verificación: Prueba

Estado: **Verificado**

RF-10 Actualización del perfil propio

Enunciado: El sistema debe permitir a un usuario autenticado actualizar su correo de notificaciones y su teléfono, y solo los suyos.

Prioridad: Should

Fuente: OWASP A01; hallazgo de control de acceso de la auditoría del 2026-08-11/12, que separó el correo institucional (identificador de cuenta) de los datos de contacto del titular.

Endpoint: PATCH/api/usuarios/{id}/perfil

Rationale: El correo institucional identifica la cuenta y no debe poder cambiarlo el propio usuario; el correo de notificaciones y el teléfono son datos de contacto y sí le pertenecen.

Criterio de aceptación:

- Un intento de editar el perfil de otro usuario responde 403, aunque quien lo intente sea Administrador.
- La operación no modifica el correo institucional, el rol ni el estado activo, aunque se envíen en el cuerpo.

Método de verificación: Prueba

Estado: **Verificado**

Depende de: RNF-13

RF-11 Gestión de roles

Enunciado: El sistema debe permitir al Administrador consultar, crear, renombrar y eliminar roles de usuario, conservando invariable el código del rol.

Prioridad: Should

Fuente: ADR-005

Endpoints: GET/api/roles, POST/api/roles, PUT/api/roles/{id}, DELETE/api/roles/{id}

Rationale: El nombre del rol es una etiqueta de presentación; su código es la clave que usan las reglas de autorización. Permitir renombrar sin tocar el código deja adaptar el vocabulario institucional sin romper el control de acceso.

Criterio de aceptación:

- Renombrar un rol devuelve 200 y el código del rol permanece inalterado.
- Eliminar un rol con usuarios asignados se rechaza con 400.
- Sin el permiso ROLES_PERMISOS_GESTIONAR responde 403.

Método de verificación: Prueba

Estado: **Verificado**

RF-12 Asignación de permisos a un rol

Enunciado: El sistema debe permitir al Administrador consultar el catálogo completo de permisos y sustituir el conjunto de permisos concedidos a un rol, con efecto inmediato sobre las sesiones activas.

Prioridad: Must

Fuente: ADR-005

Endpoints: GET/api/permisos, PUT/api/permisos/rol/{rolId}

Rationale: Es lo que hace que la matriz de la sección 6 sea configuración y no código: permite corregir una asignación indebida sin recompilar ni desplegar.

Criterio de aceptación:

- Responde 200 y el conjunto de permisos del rol queda exactamente en el enviado, sin residuos de la asignación anterior.
- Tras el cambio, una petición de un usuario de ese rol a un endpoint cuyo permiso se retiró responde 403 **sin necesidad de volver a iniciar sesión**.
- Sin el permiso ROLES_PERMISOS_GESTIONAR responde 403.
- El cambio queda registrado en la bitácora de auditoría (RNF-18).

Método de verificación: Prueba

Estado: **Verificado**

Nota: Este requisito puede dejar el sistema sin ningún usuario capaz de administrar permisos si se retira ROLES_PERMISOS_GESTIONAR al rol ADMIN. Esa salvaguarda no está especificada ni construida, y queda como deuda declarada (§13).

7.3. Solicitud de pre-sustentación

RF-13 Registro de la solicitud de pre-sustentación

Enunciado: El sistema debe registrar la solicitud de pre-sustentación de un estudiante con el título del tema, la modalidad de titulación y la convocatoria, dejándola en estado CREADA.

Prioridad: Must

Fuente: HU-02, CU-02

Endpoints: POST/api/solicitudes/crear-por-usuario/{usuarioId}, POST/api/solicitudes/crear/{estudianteId}

Rationale: Es el hecho que abre el expediente: todo el resto del proceso cuelga de esta solicitud. Registrarla como CREADA y no como ENVIADA separa la redacción del compromiso, y deja al estudiante

corregir antes de someterla.

Criterio de aceptación:

- El título del tema es obligatorio y no excede 300 caracteres; en otro caso responde 400 sin crear la solicitud.
- La modalidad de titulación es obligatoria; sin ella responde 400.
- Si no se indica convocatoria, el sistema debe resolver la convocatoria activa; si no hay ninguna activa responde 400.
- Si se indica un área temática que no pertenece a la línea de investigación declarada, responde 400.
- La solicitud creada queda en estado CREADA conforme a la sección 5, y al perfil de estudiante se le genera su código de expediente.

Método de verificación: Prueba

Estado: **Verificado**

RF-14 Envío de la solicitud a revisión

Enunciado: El sistema debe permitir al estudiante propietario enviar su solicitud a revisión, pasándola de CREADA a ENVIADA.

Prioridad: Must

Fuente: HU-02, CU-02

Endpoint: POST/api/solicitudes/enviar/{id}

Rationale: Es el acto por el cual el estudiante asume la solicitud como definitiva y la somete a la coordinación; sin él, la coordinación no puede distinguir un borrador de una postulación.

Criterio de aceptación:

- Enviar una solicitud ajena responde 403.
- La solicitud queda en estado ENVIADA y el cambio se registra en el historial de estados con el usuario que lo realizó.
- Enviar una solicitud que no esté en CREADA responde 400.

Método de verificación: Prueba

Estado: **Verificado**

Depende de: RF-13

RF-15 Aprobación o rechazo de la solicitud

Enunciado: El sistema debe permitir a quien posea el permiso SOLICITUDES_REVISAR aprobar o rechazar una solicitud enviada, y rechazarla dejando una observación dirigida al estudiante.

Prioridad: Must

Fuente: HU-02, CU-02

Endpoints: POST/api/solicitudes/aprobar/{id}, POST/api/solicitudes/rechazar/{id}, POST/api/solicitudes/rechazar-con-observacion/{id}

Rationale: Un rechazo sin motivo obliga al estudiante a adivinar qué corregir. Separar el rechazo con observación del rechazo simple permite exigir el motivo donde importa sin bloquear el caso en que la solicitud es inadmisible de plano.

Criterio de aceptación:

- Aprobar deja la solicitud en APROBADA; rechazar, en RECHAZADA.
- El rechazo con observación exige el texto de la observación; sin él responde 400.
- Sin el permiso SOLICITUDES_REVISAR responde 403.
- Toda transición queda registrada en el historial de estados con usuario, estado anterior, estado nuevo y fecha.
- El estudiante recibe una notificación con el resultado (RF-41).

Método de verificación: Prueba

Estado: **Verificado**

RF-16 Suspensión de una solicitud

Enunciado: El sistema debe permitir a quien posea el permiso SOLICITUDES_SUSPENDER suspender una solicitud en curso indicando el motivo, y una solicitud suspendida no debe admitir cargas de archivo por parte del estudiante.

Prioridad: Should

Fuente: Reglamento de titulación: detención del proceso por decisión académica. Modelado en la migración V1__schema_inicial.sql (campos motivo_suspension y suspendido_en de la solicitud) y permiso SOLICITUDES_SUSPENDER de V13__permisos_roles_dinamicos.sql.

Endpoint: POST/api/solicitudes/suspender/{id}

Rationale: Detener un proceso sin motivo registrado deja al estudiante sin explicación y a la institución sin traza de la decisión. La suspensión es reversible en su intención y distinta del rechazo, que cierra el expediente.

Criterio de aceptación:

- El motivo de suspensión es obligatorio; sin él responde 400.
- Solo son suspendibles las solicitudes en un estado distinto de CREADA, RECHAZADA y SUSPENDIDA; en otro caso responde 400.
- Tras la suspensión, la carga del anteproyecto (RF-19) responde 400 indicando el motivo registrado.
- Sin el permiso SOLICITUDES_SUSPENDER responde 403.

Método de verificación: Prueba

Estado: **Implementado**

Nota: La reanudación de una solicitud suspendida no está especificada ni construida: hoy SUSPENDIDA es terminal. Queda como deuda declarada (§13).

RF-17 Consulta y seguimiento de la solicitud propia

Enunciado: El sistema debe permitir al estudiante consultar sus propias solicitudes y el seguimiento del avance de cada una, expresado como porcentaje y como etapa alcanzada.

Prioridad: Must

Fuente: HU-02, CU-02

Endpoints: GET/api/solicitudes/mis-solicitudes, GET/api/solicitudes/{id}, GET/api/solicitudes/{id}/seguimiento

Rationale: El estudiante es el actor con menos visibilidad del proceso y el más afectado por él; sin seguimiento propio, cada consulta de estado se convierte en un trámite presencial.

Criterio de aceptación:

- Devuelve exclusivamente las solicitudes del estudiante en sesión.
- Consultar el detalle o el seguimiento de una solicitud ajena responde 403.
- El seguimiento devuelve la etapa alcanzada conforme a los estados de la sección 5 y un porcentaje coherente con esa etapa.

Método de verificación: Prueba

Estado: Verificado

Depende de: RNF-13

RF-18 Consulta administrativa de solicitudes

Enunciado: El sistema debe permitir a quien posea el permiso SOLICITUDES_REVISAR listar las solicitudes de forma completa y paginada, filtrarlas por estudiante, contarlas por estado y obtener el reporte de defensas.

Prioridad: Should

Fuente: HU-09, CU-09

Endpoints: GET/api/solicitudes, GET/api/solicitudes/paginado, GET/api/solicitudes/contar-por-estado, GET/api/solicitudes/estudiante/{estudianteId}, GET/api/solicitudes/reporte-defensas

Rationale: Es la vista de gestión de la coordinación. El conteo por estado alimenta los indicadores de RF-56 sin recalcularlos en el cliente.

Criterio de aceptación:

- Sin el permiso SOLICITUDES_REVISAR responde 403 en las cinco operaciones.
- La consulta paginada acepta número de página y tamaño, y devuelve el total de elementos junto con la página solicitada.
- El conteo por estado usa exclusivamente los códigos de la sección 5.

Método de verificación: Prueba

Estado: **Verificado**

7.4. Anteproyecto y tutoría

RF-19 Carga del anteproyecto en PDF

Enunciado: El sistema debe permitir al estudiante propietario de la solicitud cargar el anteproyecto en formato PDF, calculando y almacenando su resumen criptográfico SHA-256 en el momento de la carga.

Prioridad: Must

Fuente: HU-12, CU-12

Endpoint: POST/api/anteproyectos/enviar/{solicitudId}

Rationale: El anteproyecto es el documento que el tribunal evalúa. Calcular el resumen en el momento de la carga, y no después, es lo que permite demostrar más tarde que el archivo entregado es el mismo que se evaluó.

Criterio de aceptación:

- Un archivo cuyo tipo de contenido no sea `application/pdf` se rechaza con 400 y no se almacena.
- Un archivo de más de **10 MB** se rechaza con 400 y no se almacena.
- Cargar el anteproyecto de una solicitud ajena responde 403.
- Si la solicitud está **SUSPENDIDA**, la carga responde 400 indicando el motivo de suspensión.
- Con un anteproyecto ya cargado y no rechazado, un segundo envío responde 400: el reemplazo exige que el revisor lo rechace primero (RF-21).
- El registro almacena el resumen SHA-256 en 64 caracteres hexadecimales y el tamaño en bytes.

Método de verificación: Prueba

Estado: **Verificado**

Depende de: RF-13, RF-16

RF-20 Verificación de integridad del anteproyecto

Enunciado: El sistema debe permitir verificar que el archivo almacenado de un anteproyecto coincide con el resumen SHA-256 registrado en el momento de su carga, e informar el resultado de esa comparación.

Prioridad: Should

Fuente: HU-12, CU-12; hallazgo de análisis estático `UNSAFE_HASH_EQUALS` corregido el 2026-08-29

Endpoints: GET/api/anteproyectos/verificar/{solicitudId}, GET/api/anteproyectos/ver/{solicitudId}, GET/api/anteproyectos/solicitud/{solicitudId}

Rationale: Guardar un resumen que nadie comprueba no aporta integridad. La comparación debe hacerse en tiempo constante para que no filtre información sobre el valor esperado.

Criterio de aceptación:

- Con el archivo íntegro responde 200 declarando la coincidencia.
- Si el archivo fue alterado o falta, responde 200 declarando explícitamente la **no** coincidencia; no devuelve un error genérico que confunda «alterado» con «no encontrado».
- La comparación de resúmenes no se realiza con una comparación de cadenas que termine en el primer byte distinto.

Método de verificación: Prueba + Inspección

Estado: **Verificado**

RF-21 Revisión del anteproyecto

Enunciado: El sistema debe permitir a quien posea el permiso ANTEPROYECTO_REVISAR aprobar o rechazar el anteproyecto cargado, y el rechazo debe habilitar al estudiante a cargar una versión nueva.

Prioridad: Must

Fuente: HU-12, CU-12

Endpoints: POST/api/anteproyectos/aprobar/{id}, POST/api/anteproyectos/rechazar/{id}

Rationale: Es la puerta que RF-19 cierra: el estudiante no puede sustituir el documento por su cuenta, así que el rechazo del revisor es el único mecanismo que reabre la carga. Sin este requisito, el bloqueo de RF-19 sería un callejón sin salida.

Criterio de aceptación:

- Aprobar deja el anteproyecto en APROBADO; rechazar, en RECHAZADO.
- Tras el rechazo, una nueva carga por RF-19 responde 200.
- Sin el permiso ANTEPROYECTO_REVISAR responde 403.
- El estudiante recibe una notificación con el resultado (RF-41).

Método de verificación: Prueba

Estado: **Verificado**

RF-22 Asignación del tutor

Enunciado: El sistema debe permitir a quien posea el permiso TRIBUNAL_TUTOR_ASIGNAR asignar un docente como tutor de una solicitud, y consultar y retirar esa asignación.

Prioridad: Must

Fuente: HU-03, CU-03

Endpoints: POST/api/jurados/tutor/asignar, POST/api/tutores/asignar, GET/api/tutores/solicitud/{solicitudId}, GET/api/tutores/mis-estudiantes, DELETE/api/tutores/{id}

Rationale: El tutor es el primer rol funcional que se fija sobre la solicitud, y de él depende que puedan abrirse las fases de tutoría (RF-23) y, más adelante, el tribunal (RF-26).

Criterio de aceptación:

- Una solicitud admite un único tutor; asignar un segundo responde 400.
- La asignación deja la tutoría en estado **ACTIVO** y la solicitud en **TUTORIA**.
- El docente asignado y el estudiante reciben notificación (RF-41).
- Sin el permiso **TRIBUNAL_TUTOR_ASIGNAR** responde 403.
- Un docente consulta sus propios estudiantes tutorados sin necesidad de ese permiso, y solo los suyos.

Método de verificación: Prueba

Estado: **Verificado**

RF-23 Gestión de las tres fases de tutoría

Enunciado: El sistema debe permitir al tutor abrir fases de revisión sobre una tutoría, hasta un máximo de tres, y consultar el resumen y el detalle de esas fases.

Prioridad: Must

Fuente: Reglamento de titulación: tres revisiones obligatorias antes de conformar el tribunal. Modelado en `V1__schema_inicial.sql` (tabla `tutoria_fases`).

Endpoints: `POST/api/tutorias/{tutorId}/nueva-fase`, `GET/api/tutorias/{tutorId}/fases`, `GET/api/tutorias/{tutorId}/resumen`, `GET/api/tutorias/estudiante/{usuarioId}`, `GET/api/tutorias/docente/{usuarioId}`

Rationale: Las tres revisiones son la condición que el reglamento impone antes de conformar el tribunal. El número está fijado en el sistema y hasta esta versión vivía únicamente en el código: una regla de negocio que solo existe en el código no es una regla especificada.

Criterio de aceptación:

- El máximo de fases por tutoría es **3**; crear una cuarta responde 400.
- Cada fase se numera consecutivamente de 1 a 3 y nace en estado **PENDIENTE_ESTUDIANTE**.
- Sin el permiso **TUTORIA_GESTIONAR** responde 403.
- Un docente que no es el tutor de esa solicitud responde 403 aunque posea el permiso.

Método de verificación: Prueba

Estado: **Verificado**

RF-24 Entrega de correcciones del estudiante en una fase

Enunciado: El sistema debe permitir al estudiante cargar un archivo PDF con sus correcciones en una fase de tutoría abierta, calculando y almacenando su resumen SHA-256.

Prioridad: Must

Fuente: Reglamento de titulación: entrega de correcciones por fase. Modelado en `V1__schema_inicial.sql` (campos `archivo_pdf_estudiante`, `sha256_pdf` y `tamano_pdf_bytes` de la fase).

Endpoints: `POST/api/tutorias/fases/{faseId}/subir-pdf`, `GET/api/tutorias/fases/{faseId}/pdf`

Rationale: Es la contraparte del estudiante en el ciclo de tutoría, y la que produce el documento que en la fase 3 se convierte en el anteproyecto definitivo (RF-26).

Criterio de aceptación:

- Un archivo cuyo tipo de contenido no sea `application/pdf` se rechaza con 400.
- Cargar en una fase que no esté esperando al estudiante responde 400.
- Cargar en una fase de otra tutoría responde 403.
- Sin el permiso `TUTORIA_AVANCE_ESTUDIANTE` responde 403.
- La fase registra el resumen SHA-256 y el tamaño en bytes del archivo entregado.

Método de verificación: Prueba

Estado: **Verificado**

RF-25 Mensajería de la fase de tutoría

Enunciado: El sistema debe permitir al tutor y al estudiante intercambiar mensajes dentro de una fase, clasificados como observación, respuesta o aprobación, y marcar los recibidos como leídos.

Prioridad: Should

Fuente: Migración `V1__schema_inicial.sql`: tabla `tutoria_mensajes` y catálogo `tipos_mensaje`, que fijan el conjunto cerrado de tipos de mensaje.

Endpoints: `POST/api/tutorias/fases/{faseId}/mensaje`, `PUT/api/tutorias/fases/{faseId}/leer`

Rationale: Las observaciones de tutoría deben quedar asociadas a la fase y al documento que las motivó; fuera del sistema se pierden y no son auditables.

Criterio de aceptación:

- El tipo de mensaje pertenece al conjunto cerrado `OBSERVACION`, `RESPUESTA`, `APROBACION`; cualquier otro responde 400.
- Publicar o leer mensajes de una fase ajena responde 403.
- Un mensaje del tutor de tipo `OBSERVACION` deja la fase en `PENDIENTE_ESTUDIANTE`.

Método de verificación: Prueba

Estado: **Implementado**

RF-26 Aprobación de la fase y cierre de la tutoría

Enunciado: El sistema debe permitir al tutor aprobar una fase que tenga entrega del estudiante y, cuando las tres fases queden aprobadas, cerrar la tutoría promoviendo el documento de la fase 3 a

anteproyecto definitivo con su resumen SHA-256.

Prioridad: Must

Fuente: Reglamento de titulación: el cierre de la tutoría es precondition de la conformación del tribunal (RF-27).

Endpoints: POST/api/tutorias/fases/{faseId}/aprobar, POST/api/tutorias/{tutorId}/registrar-avance

Rationale: Este es el punto donde el acompañamiento se convierte en entregable, y la condición que RF-27 exige para conformar el tribunal. Promover el documento de la fase 3 conservando su resumen evita que el anteproyecto evaluado difiera del último aprobado.

Criterio de aceptación:

- Aprobar una fase sin entrega del estudiante responde 400.
- Con las tres fases aprobadas, la tutoría queda en COMPLETADA.
- Al cerrarse, el anteproyecto de la solicitud queda con el archivo, el resumen SHA-256 y el tamaño del documento de la fase 3.
- Sin el permiso TUTORIA_GESTIONAR responde 403; un docente que no es el tutor de esa solicitud responde 403 aunque lo posea.

Método de verificación: Prueba

Estado: Verificado

Depende de: RF-23, RF-24

7.5. Tribunal, cronograma y salas

RF-27 Conformación del tribunal

Enunciado: El sistema debe permitir a quien posea el permiso TRIBUNAL_TUTOR_ASIGNAR asignar a una solicitud tres docentes con los roles PRESIDENTE, VOCAL_1 y VOCAL_2, solo cuando la tutoría de esa solicitud esté completada.

Prioridad: Must

Fuente: HU-03, CU-03

Endpoints: POST/api/jurados/asignar, POST/api/jurados/asignar-automatico/{solicitudId}, GET/api/jurados/solicitud/{solicitudId}, GET/api/jurados, DELETE/api/jurados/{juradoId}

Rationale: Concentra las cuatro reglas que garantizan la validez del tribunal: momento del proceso, unicidad del docente, unicidad del rol y ausencia de conflicto de interés. Ninguna de ellas estaba especificada hasta esta versión.

Criterio de aceptación:

- Si la tutoría de la solicitud no está COMPLETADA, responde 400 indicando que faltan las tres revisiones obligatorias.

- El rol pertenece al conjunto cerrado PRESIDENTE, VOCAL_1, VOCAL_2; cualquier otro responde 400.
- Un docente ya asignado a esa solicitud no puede asignarse de nuevo: responde 400.
- Un rol ya ocupado en esa solicitud no puede volver a asignarse: responde 400.
- **El tutor de la solicitud no puede ser además jurado de la misma solicitud;** el intento responde 400 por conflicto de interés.
- Un docente marcado como no disponible no puede asignarse: responde 400.
- Conformado el tribunal, la solicitud pasa a EVALUACION.

Método de verificación: Prueba

Estado: **Verificado**

Depende de: RF-26

RF-28 Asignación masiva de tribunales y sugerencia de jurados

Enunciado: El sistema debe permitir conformar tribunales para varias solicitudes en una sola operación, y sugerir docentes candidatos para una solicitud dada.

Prioridad: Should

Fuente: HU-03, CU-03; ADR-006 (la asignación masiva se resuelve en procedimiento almacenado)

Endpoints: POST/api/jurados/asignar-masivo, GET/api/jurados/sugerencias/{solicitudId}, GET/api/jurados/docente/{docenteId}, GET/api/jurados/tutor/docente/{docenteId}, GET/api/jurados/info/{solicitudId}/{usuarioId}

Rationale: En una convocatoria la coordinación conforma decenas de tribunales el mismo día; hacerlo de uno en uno es donde aparecen los errores de rol repetido y de conflicto de interés que RF-27 rechaza.

Criterio de aceptación:

- La operación masiva aplica a cada solicitud las mismas cinco reglas de RF-27, y devuelve por cada una si se asignó o el motivo del rechazo, sin abortar el lote completo por un fallo individual.
- La sugerencia nunca propone al tutor de esa solicitud ni a un docente ya asignado.
- Un docente puede consultar sus propias asignaciones como jurado o tutor sin el permiso TRIBUNAL_TUTOR_ASIGNAR, y solo las suyas.

Método de verificación: Prueba

Estado: **Verificado**

RF-29 Programación del cronograma de defensa

Enunciado: El sistema debe programar la defensa de una solicitud en una sala, fecha y hora determinadas, con una duración de 45 minutos, rechazando la programación si la sala o alguno de los miembros del tribunal ya está ocupado en ese intervalo.

Prioridad: Must

Fuente: HU-04, CU-04; ADR-006 (la validación de conflicto de jurado es un procedimiento almacenado)

Endpoints: POST/api/cronogramas/crear, POST/api/cronogramas/auto/{solicitudId}, GET/api/cronogramas, GET/api/cronogramas/solicitud/{id}, GET/api/cronogramas/estudiante/{id}, GET/api/cronogramas/usuario/{id}, DELETE/api/cronogramas/{id}

Rationale: Un choque de agenda descubierto el día de la defensa cuesta una reprogramación completa. La duración fija de 45 minutos y la ventana de búsqueda automática de 30 días son reglas de negocio que hasta esta versión vivían solo en el código.

Criterio de aceptación:

- La duración de toda defensa programada es de **45 minutos**.
- Si la sala tiene otra defensa que se solapa con ese intervalo, responde 400 nombrando la sala.
- Si algún miembro del tribunal tiene otra defensa que se solapa, responde 400 nombrando al docente.
- La programación automática busca la primera franja libre en los **próximos 30 días** sobre las salas disponibles; si no encuentra ninguna responde 400 declarándolo, en vez de programar en una franja ocupada.
- Sin el permiso CRONOGRAMA_GESTIONAR responde 403 en la creación y en la eliminación.
- El cronograma creado queda en estado PROGRAMADO.

Método de verificación: Prueba

Estado: Verificado

Depende de: RF-27, RF-31

RF-30 Consulta de disponibilidad de salas y franjas

Enunciado: El sistema debe informar las franjas horarias disponibles y verificar la disponibilidad de una sala en un instante dado, antes de intentar la programación.

Prioridad: Should

Fuente: HU-04, HU-10

Endpoints: GET/api/cronogramas/disponibilidad, GET/api/cronogramas/verificar-disponibilidad

Rationale: Sin consulta previa, la única forma de saber si una franja está libre es intentar programar y recibir el rechazo de RF-29, lo que convierte una consulta en un intento fallido.

Criterio de aceptación:

- La disponibilidad devuelta es coherente con las reglas de conflicto de RF-29: una franja informada como libre no puede ser rechazada por solapamiento de sala.
- La verificación puntual responde 200 declarando disponible o no disponible, sin crear ningún cronograma.

Método de verificación: Prueba

Estado: **Implementado**

RF-31 Gestión de salas de sustentación

Enunciado: El sistema debe permitir consultar las salas y, a quien posea el permiso `SALA_GESTIONAR`, crearlas y eliminarlas, con código único, nombre, capacidad y disponibilidad.

Prioridad: Should

Fuente: HU-10, CU-10

Endpoints: `GET/api/salas`, `GET/api/salas/paginado`, `POST/api/salas`, `DELETE/api/salas/{id}`

Rationale: Las salas son el recurso escaso que RF-29 reparte; sin catálogo, la programación automática no tiene sobre qué buscar.

Criterio de aceptación:

- Un código de sala duplicado responde 400.
- Eliminar una sala con defensas programadas responde 400 en vez de dejar cronogramas huérfanos.
- Sin el permiso `SALA_GESTIONAR` la creación y la eliminación responden 403; la consulta está abierta a cualquier usuario autenticado.
- Una sala marcada como no disponible no es candidata de la programación automática de RF-29.

Método de verificación: Prueba

Estado: **Implementado**

Nota: Era el requisito RF-10 de la especificación anterior, declarado allí «no verificado» porque la clase de prueba que citaba no existía. Sigue sin prueba dedicada; el estado se declara **Implementado** conforme al vocabulario de la sección 2.5, que distingue construido de verificado.

7.6. Evaluación por rúbrica

RF-32 Gestión de rúbricas y de sus criterios

Enunciado: El sistema debe permitir a quien posea el permiso `RUBRICA_GESTIONAR` crear y eliminar rúbricas, definir sus criterios y sembrar el conjunto de criterios por omisión de una rúbrica, y debe permitir a cualquier usuario autenticado consultarlas.

Prioridad: Must

Fuente: HU-05, CU-05

Endpoints: `GET/api/rubricas`, `GET/api/rubricas/{id}`, `POST/api/rubricas`, `DELETE/api/rubricas/{id}`, `POST/api/rubricas/{rubricaId}/criterios`, `GET/api/rubricas/{rubricaId}/criterios`, `POST/api/rubricas/{rubricaId}/inicializar-criterios`

Rationale: La rúbrica es el instrumento que hace comparable la evaluación entre tribunales distintos. Sin criterios definidos, RF-33 no tiene sobre qué registrar.

Criterio de aceptación:

- Sin el permiso `RUBRICA_GESTIONAR`, crear, eliminar o definir criterios responde **403**; la consulta está abierta a cualquier usuario autenticado.
- Eliminar una rúbrica ya utilizada en una evaluación responde **400**.
- La siembra de criterios por omisión es idempotente: repetirla no duplica criterios.

Método de verificación: Prueba

Estado: **Verificado**

RF-33 Registro de la evaluación por criterio de rúbrica

Enunciado: El sistema debe permitir a un miembro del tribunal registrar su calificación para **todos** los criterios de la rúbrica de una solicitud, en una escala de 1 a 100 por criterio, y solo a nombre propio.

Prioridad: Must

Fuente: HU-05, CU-05; hallazgo de auditoría OWASP A01 (escritura a nombre de otro jurado)

Endpoints: `POST/api/rubrica-evaluacion/registrar`, `POST/api/evaluaciones-jurado/guardar`, `GET/api/rubrica-evaluacion/criterios/{rubricaId}`, `GET/api/rubrica-evaluacion/solicitud/{solicitudId}/jurado/{juradoId}`

Rationale: Una evaluación parcial no es comparable ni promediable, y una evaluación registrada a nombre de otro jurado invalida el acta. Ambas condiciones tienen que rechazarse en el servidor, no confiarse al cliente.

Criterio de aceptación:

- Una escala fuera del intervalo **1 a 100** responde **400** declarando el valor recibido.
- Una entrega que no cubra **todos** los criterios de la rúbrica responde **400** indicando cuántos criterios exige la rúbrica.
- Registrar la evaluación a nombre de otro jurado responde **403**, aunque quien lo intente posea `VALUACION_RUBRICA_REGISTRAR`.
- Registrar una evaluación en una solicitud en la que quien la envía no es jurado responde **400**.
- Si la rúbrica no tiene criterios definidos, responde **400**.

Método de verificación: Prueba

Estado: **Verificado**

Depende de: RF-27, RF-32, RNF-13

RF-34 Cálculo de la nota final ponderada

Enunciado: El sistema debe calcular la nota final de una solicitud como la ponderación de la nota del instructor y la nota promedio del tribunal, con pesos que sumen 100, y debe derivar de esa nota el resultado `APROBADO` o `REPROBADO`.

Prioridad: Must

Fuente: HU-05, CU-05; ADR-006 (el promedio se resuelve en procedimiento almacenado)

Endpoints: POST/api/evaluaciones/evaluar-ponderado, POST/api/evaluaciones/evaluar, POST/api/evaluaciones/calcular-promedio/{solicitudId}

Rationale: Es la regla que decide si un estudiante aprueba. Sus tres constantes —los pesos por omisión, el rango de nota y el umbral de aprobación— vivían únicamente en el código hasta esta versión, de modo que ni el estudiante ni el tribunal podían conocerlas leyendo la especificación.

Criterio de aceptación:

- Los pesos por omisión son **60 % instructor** y **40 % tribunal**.
- Si los pesos enviados no suman **100** (con tolerancia 0,01), responde 400 indicando la suma recibida y no calcula nada.
- Toda nota debe estar en el intervalo **0 a 10**; fuera de él responde 400.
- El resultado es **APROBADO** si la nota final es **mayor o igual a 7,0**, y **REPROBADO** en otro caso. El resultado es calculado y no admite fijarse directamente.
- Registrada la nota final, la solicitud pasa a **CALIFICADA**.
- Sin el permiso **EVALUACION_CALIFICAR** responde 403.
- El estudiante recibe notificación de su nota final (RF-41).

Método de verificación: Prueba

Estado: **Verificado**

Depende de: RF-33

RF-35 Consulta de resultados de evaluación

Enunciado: El sistema debe permitir consultar la evaluación de una solicitud, la nota del tribunal, las evaluaciones de un estudiante y las observaciones registradas, restringiendo cada consulta a quien tenga derecho sobre ese expediente.

Prioridad: Should

Fuente: HU-05, CU-05

Endpoints: GET/api/evaluaciones, GET/api/evaluaciones/solicitud/{solicitudId}, GET/api/evaluaciones/estudiante/{estudianteId}, GET/api/evaluaciones/usuario/{usuarioId}, GET/api/rubrica-evaluacion/solicitud/{solicitudId}, GET/api/rubrica-evaluacion/nota-tribunal/{solicitudId}, GET/api/rubrica-evaluacion/observaciones/{solicitudId}, GET/api/evaluaciones-jurado/tribunal/{solicitudId}, GET/api/evaluaciones-jurado/{solicitudId}/{juradoId}

Rationale: La calificación es un dato personal sensible del estudiante; el acceso no puede depender de conocer el identificador del expediente.

Criterio de aceptación:

- Consultar las evaluaciones de otro estudiante o de otro usuario responde 403.
- El listado general de evaluaciones exige el permiso **EVALUACION_CALIFICAR**; sin él responde 403.

- La consulta de una solicitud sin evaluación registrada responde 404, no una nota vacía que pueda confundirse con un cero.

Método de verificación: Prueba

Estado: **Verificado**

Depende de: RNF-13

7.7. Acta de pre-sustentación

RF-36 Generación del acta

Enunciado: El sistema debe generar el acta de pre-sustentación de una solicitud en formato PDF, con los datos del estudiante, la composición del tribunal, la evaluación y el resultado, y dejarla en estado GENERADA.

Prioridad: Must

Fuente: HU-06, CU-06

Endpoint: POST/api/v1/actas/generar/{solicitudId}

Rationale: El acta es el documento con valor académico que sale del sistema. Exigir que exista evaluación final antes de emitirla impide producir un acta sin resultado, que sería un documento oficial vacío.

Criterio de aceptación:

- Generar el acta de una solicitud sin evaluación final registrada responde 400.
- El acta generada queda en estado GENERADA y con su archivo PDF disponible.
- El PDF contiene los datos del estudiante, la tabla del tribunal con el rol de cada miembro y su confirmación, y la evaluación con el resultado.
- Sin el permiso ACTA_GENERAR responde 403.
- La generación queda registrada en el historial de estados del acta (RF-40).

Método de verificación: Prueba

Estado: **Verificado**

Depende de: RF-34

RF-37 Firma digital multi-actor del acta

Enunciado: El sistema debe permitir que el acta sea firmada por los cuatro roles PRESIDENTE, VOCAL_1, VOCAL_2 y TUTOR, aceptando cada firma únicamente del docente que ejerce ese rol en esa solicitud, y debe cerrar el proceso cuando las cuatro firmas estén aplicadas.

Prioridad: Must

Fuente: HU-07, CU-07; ADR-006 (la firma se persiste en procedimiento almacenado)

Endpoint: POST/api/v1/actas/firmar/{actaId}

Rationale: Es el requisito que cierra todo el proceso, y el que mejor ilustra por qué un permiso no basta como control de acceso: poseer ACTA_FIRMAR habilita la funcionalidad, pero firmar como PRESIDENTE exige ser el presidente de *ese* tribunal.

Criterio de aceptación:

- El rol de firma pertenece al conjunto cerrado PRESIDENTE, VOCAL_1, VOCAL_2, TUTOR; cualquier otro responde 400.
- Firmar con un rol que el firmante no ejerce en esa solicitud responde 403, aunque posea ACTA_FIRMAR.
- Cada firma registra el rol, la fecha y la observación asociada.
- Aplicada la cuarta firma, el acta pasa a FINALIZADA, la solicitud pasa a COMPLETADA y el PDF se regenera reflejando el estado final de las firmas.
- El estudiante recibe notificación del cierre del proceso (RF-41).

Método de verificación: Prueba

Estado: Verificado

Depende de: RF-36, RF-27, RF-22

Nota: Esta versión eleva el requisito de *Should* a **Must**. La razón es que RF-37 es la única transición que lleva la solicitud a COMPLETADA: sin él, ningún expediente puede cerrarse, y un requisito del que depende el cierre del proceso no puede ser opcional. La especificación anterior lo declaraba *Should* sin justificar esa prioridad.

RF-38 Consulta y descarga del acta

Enunciado: El sistema debe permitir consultar y descargar el acta a los actores con derecho sobre ese expediente, y permitir a un docente listar exclusivamente las actas de las pre-sustentaciones en las que participa.

Prioridad: Should

Fuente: Migración V19__historial_actas_y_reportes.sql, que introduce los permisos ACTAS_VER y ACTAS_VER_PROPIAS precisamente para separar el listado completo del listado propio; OWASP A01.

Endpoints: GET/api/v1/actas, GET/api/v1/actas/mis-actas, GET/api/v1/actas/buscar, GET/api/v1/actas/{id}, GET/api/v1/actas/solicitud/{solicitudId}, GET/api/v1/actas/ver/{actaId}, GET/api/v1/actas/descargar/{actaId}, DELETE/api/v1/actas/{id}

Rationale: Separar el listado completo (ACTAS_VER) del listado propio (ACTAS_VER_PROPIAS) es lo que permite dar acceso al docente sin exponerle el expediente de toda la facultad.

Criterio de aceptación:

- El listado propio devuelve únicamente las actas en las que quien consulta es tutor o miembro del tribunal.

- Consultar o descargar un acta sobre la que no se tiene derecho responde 403, conociendo su identificador.
- Descargar un acta cuyo PDF no se ha generado responde 400.
- La eliminación exige el permiso `ACTAS_GESTIONAR`; sin él responde 403.

Método de verificación: Prueba + Demostración

Estado: **Verificado**

Depende de: RNF-13

RF-39 Cambio de estado del acta

Enunciado: El sistema debe permitir cambiar el estado de un acta únicamente por transiciones válidas conforme a la sección 5, exigiendo motivo para `OBSERVADA` y `ANULADA`.

Prioridad: Should

Fuente: Migración `V19__historial_actas_y_reportes.sql`: catálogo `estados_acta` con su campo `orden`, que es lo que define la máquina de estados de la sección 5.

Endpoint: `PATCH/api/v1/actas/{id}/estado`

Rationale: Sin una máquina de estados aplicada en el servidor, un acta podría pasar de `FINALIZADA` a `REVISADA` y reabrir un expediente cerrado sin dejar rastro de por qué.

Criterio de aceptación:

- Una transición no permitida responde 400 nombrando el estado de origen, el de destino y los estados válidos.
- Pasar a `OBSERVADA` o a `ANULADA` sin motivo responde 400.
- Fijar el estado que el acta ya tiene responde 400.
- La transición a `ANULADA` desde cualquier estado está reservada al Administrador; para el resto de actores rigen las transiciones de la tabla.
- Sin el permiso `ACTA_ESTADO_CAMBIAR` responde 403.

Método de verificación: Prueba + Demostración

Estado: **Verificado**

RF-40 Historial de estados del acta

Enunciado: El sistema debe registrar cada cambio de estado de un acta con el usuario, su rol, el estado anterior, el estado nuevo, el motivo y la fecha, y permitir consultar ese historial a quien tenga derecho sobre el acta.

Prioridad: Should

Fuente: Migración `V19__historial_actas_y_reportes.sql`: tabla `historial_estados_acta` y permiso `ACTA_HISTORIAL_VER`.

Endpoint: `GET/api/v1/actas/{id}/historial`

Rationale: El acta es el documento con efectos académicos; saber quién la observó o la anuló, y por qué, es parte del documento tanto como su contenido.

Criterio de aceptación:

- Cada cambio de estado de RF-39 y la generación de RF-36 producen exactamente una entrada de historial.
- Consultar el historial de un acta ajena responde 403.
- Sin el permiso ACTA_HISTORIAL_VER responde 403.
- Las entradas del historial no son editables ni eliminables por la API.

Método de verificación: Prueba + Inspección

Estado: **Verificado**

7.8. Comunicación y apoyo al usuario

RF-41 Notificaciones al usuario

Enunciado: El sistema debe registrar una notificación dirigida al usuario afectado en cada hito del proceso, y permitirle consultarlas, filtrar las no leídas, marcarlas como leídas individualmente o en bloque, y eliminarlas.

Prioridad: Should

Fuente: HU-08, CU-08

Endpoints: GET/api/v1/notificaciones/usuario/{usuarioId}, GET/api/v1/notificaciones/usuario/{usuarioId}/no-leidas, PATCH/api/v1/notificaciones/{id}/marcar-leida, PATCH/api/v1/notificaciones/usuario/{usuarioId}/marcar-todas-leidas, DELETE/api/v1/notificaciones/{id}

Rationale: Los hitos del proceso ocurren sin que el afectado esté conectado. La notificación interna es lo que evita que el estudiante tenga que consultar su estado a diario para enterarse de una decisión.

Criterio de aceptación:

- Se registra notificación al menos en: aprobación o rechazo de la solicitud (RF-15), resultado de la revisión del anteproyecto (RF-21), asignación de tutor (RF-22), carga del anteproyecto, nota final (RF-34) y cierre del acta (RF-37).
- Consultar, marcar o eliminar notificaciones de otro usuario responde 403.
- El listado global de notificaciones del sistema exige el permiso NOTIFICACIONES_GLOBAL_VER; sin él responde 403.
- Si el envío de correo saliente está desactivado o el proveedor falla, la notificación interna **se registra igualmente**: la entrega por correo es un canal adicional, no la notificación.

Método de verificación: Prueba

Estado: **Verificado**

RF-42 Envío manual de notificaciones

Enunciado: El sistema debe permitir a quien posea el permiso NOTIFICACIONES_ENVIAR crear una notificación dirigida a un usuario determinado.

Prioridad: Could

Fuente: HU-08

Endpoints: POST/api/v1/notificaciones/crear, GET/api/v1/notificaciones

Rationale: Cubre las comunicaciones que no corresponden a un hito automatizado, sin obligar a la coordinación a salir del sistema.

Criterio de aceptación:

- Sin el permiso NOTIFICACIONES_ENVIAR responde 403.
- El destinatario debe existir; en otro caso responde 400.
- La notificación creada aparece en el listado del destinatario (RF-41).

Método de verificación: Prueba

Estado: **Implementado**

RF-43 Consulta del estado del proceso en tiempo real

Enunciado: El sistema debe exponer, en una sola petición, el estado consolidado del proceso de una solicitud, y admitir la consulta consolidada de varias solicitudes en lote.

Prioridad: Should

Fuente: ADR-001: la actualización de estado se resuelve por sondeo periódico y no por canal persistente, decisión que además determina la directiva `connect-src` de RNF-10.

Endpoints: GET/api/estado/solicitud/{id}, POST/api/estado/solicitudes/batch

Rationale: El cliente refresca el estado cada 15 segundos. Sin un endpoint consolidado tendría que encadenar cinco llamadas por solicitud, multiplicando por cinco la carga de un sondeo que ya es periódico. La actualización se resuelve por sondeo y **no** por *WebSocket*; declararlo evita que la política de seguridad de contenido reserve permisos para un canal que no existe.

Criterio de aceptación:

- Devuelve en una respuesta el estado de la solicitud, la tutoría, el tribunal, el cronograma y el acta.
- La consulta en lote devuelve un elemento por identificador solicitado, sin fallar el lote completo por una solicitud inexistente.
- Consultar el estado de una solicitud ajena responde 403.

Método de verificación: Prueba

Estado: **Implementado**

RF-44 Asistente virtual de ayuda

Enunciado: El sistema debe responder consultas de ayuda del usuario autenticado sobre los módulos del sistema, y ofrecer el conjunto de temas disponibles en cada respuesta.

Prioridad: Could

Fuente: Observación docente OBS-17 (`docs/observaciones/OBSERVACIONES.md`), que exigió someter el asistente al control de acceso del resto de la API.

Endpoint: `POST/api/v1/chatbot/ask`

Rationale: Reduce las consultas de trámite a la coordinación. La resolución es interna y determinista, sin consumir ningún proveedor externo de modelo de lenguaje: eso mantiene el requisito dentro del alcance de RNF-20 y evita que el mensaje del usuario salga del sistema.

Criterio de aceptación:

- Sin autenticación responde indicando que se requiere iniciar sesión, sin procesar el mensaje.
- Ante un mensaje que no reconoce, responde declarando que no puede responderlo y ofrece los temas disponibles, en vez de inventar una respuesta.
- **El mensaje del usuario no se envía a ningún servicio externo**, y ninguna respuesta incluye datos de otro usuario.
- Toda respuesta incluye la lista de temas soportados.

Método de verificación: Prueba + Inspección

Estado: **Verificado**

RF-45 Consulta del directorio de universidades

Enunciado: El sistema debe ofrecer al usuario autenticado el listado de universidades del Ecuador obtenido del directorio externo, con resultado cacheado y con una respuesta de reserva cuando el proveedor no está disponible.

Prioridad: Could

Fuente: Criterio de consumo de API externa de la asignatura

Endpoint: `GET/api/universidades`

Rationale: Es la única dependencia externa de datos del sistema. La reserva local existe para que la indisponibilidad de un tercero no se convierta en un error de esta aplicación.

Criterio de aceptación:

- Con el proveedor disponible responde 200 con el listado.
- El resultado se sirve desde caché durante **10 minutos** antes de volver a consultar al proveedor.
- Ante error o tiempo de espera del proveedor, tras **3 reintentos** con retroceso exponencial desde 1 s, responde 200 con la entrada de reserva local; nunca propaga un **5xx** al cliente.
- Los tiempos de espera de conexión, lectura y escritura son de **5 segundos**.

- Ninguna petición al proveedor incluye datos de un usuario del sistema.

Método de verificación: Prueba + Análisis

Estado: **Verificado**

Nota: El análisis estadístico de caché fría contra caché caliente sobre este endpoint está archivado en k6/README.md (30 muestras por escenario, prueba de Wilcoxon, IC 95 %).

7.9. Centro de orientación de titulación

RF-46 Exploración del catálogo de temas propuestos

Enunciado: El sistema debe permitir a quien posea el permiso `ORIENTACION_TEMAS_VER` explorar el catálogo de temas de titulación propuestos y consultar el detalle de un tema.

Prioridad: Should

Fuente: docs/funcionalidades/CENTRO-ORIENTACION.md y migraciones V20 a V23, que crean el módulo y siembran su catálogo.

Endpoints: `GET/api/v1/orientacion/temas`, `GET/api/v1/orientacion/temas/{temaId}`

Rationale: La elección del tema es el punto donde más estudiantes se detienen. El catálogo convierte esa decisión en una elección informada sobre líneas de investigación reales de la carrera.

Criterio de aceptación:

- Los cuatro roles poseen `ORIENTACION_TEMAS_VER` en la asignación inicial (sección 6); sin el permiso responde 403.
- El catálogo admite filtrado por línea de investigación y por área temática.
- Un tema inexistente responde 404.

Método de verificación: Prueba

Estado: **Verificado**

RF-47 Generación de ideas de tema

Enunciado: El sistema debe generar propuestas de tema a partir de la línea de investigación y el área temática indicadas por el usuario, sin persistirlas automáticamente.

Prioridad: Could

Fuente: docs/funcionalidades/CENTRO-ORIENTACION.md: el objetivo declarado del módulo es que el estudiante explore ideas *antes* de registrar su solicitud.

Endpoint: `POST/api/v1/orientacion/temas/generar`

Rationale: Una sugerencia es una recomendación, no un hecho: persistirla sola convertiría una propuesta que nadie eligió en parte del expediente. Solo el acto explícito de RF-48 la guarda. La generación es **interna**, sin proveedor externo, en coherencia con RNF-20.

Criterio de aceptación:

- Si el área temática indicada no pertenece a la línea de investigación declarada, responde 400.
- Las propuestas devueltas **no se persisten** como temas del estudiante.
- **Ningún dato del usuario se envía a un servicio externo** en esta operación.
- Sin el permiso ORIENTACION_TEMAS_VER responde 403.

Método de verificación: Prueba + Inspección

Estado: **Implementado**

RF-48 Temas guardados por el estudiante

Enunciado: El sistema debe permitir a un usuario con rol ESTUDIANTE guardar y retirar temas de su lista personal, y consultarla.

Prioridad: Could

Fuente: docs/funcionalidades/CENTRO-ORIENTACION.md y migración V21, que siembra el catálogo de temas sobre el que se guarda.

Endpoints: GET/api/v1/orientacion/temas/guardados, POST/api/v1/orientacion/temas/{temaId}/guardar, DELETE/api/v1/orientacion/temas/{temaId}/guardar

Rationale: Es lo que hace del catálogo una herramienta de decisión y no solo un listado: permite comparar candidatos antes de comprometerse en RF-13.

Criterio de aceptación:

- Guardar un tema ya guardado responde 400 sin duplicar la entrada.
- Retirar un tema que no estaba guardado responde 400.
- La lista devuelta contiene exclusivamente los temas del estudiante en sesión.
- Un usuario cuyo rol no es ESTUDIANTE responde 403.

Método de verificación: Prueba

Estado: **Verificado**

RF-49 Gestión del catálogo de orientación

Enunciado: El sistema debe permitir a quien posea el permiso ORIENTACION_CATALOGO_GESTIONAR crear, editar y eliminar temas propuestos y recursos de titulación.

Prioridad: Should

Fuente: Migración V21__orientacion_permisos_y_semilla_temas.sql, que crea el permiso ORIENTACION_CATALOGO_GESTIONAR para curar el catálogo que RF-46 da por hecho.

Endpoints: POST/api/v1/orientacion/temas, PUT/api/v1/orientacion/temas/{temaId}, DELETE/api/v1/orientacion/temas/{temaId}, POST/api/v1/orientacion/recursos, PUT/api/v1/orientacion/recursos/{id}, DELETE/api/v1/orientacion/recursos/{id}

Rationale: RF-46 da por hecho un catálogo curado; sin este requisito no existiría el mecanismo que lo mantiene, y el catálogo quedaría congelado en su siembra inicial.

Criterio de aceptación:

- Sin el permiso `ORIENTACION_CATALOGO_GESTIONAR` las seis operaciones responden 403.
- Un tema con el área temática incoherente con su línea de investigación responde 400.
- Eliminar un tema guardado por algún estudiante lo retira también de esas listas personales, sin dejar referencias colgantes.

Método de verificación: Prueba

Estado: **Verificado**

RF-50 Consulta de recursos de titulación

Enunciado: El sistema debe ofrecer a cualquier usuario autenticado el catálogo de recursos de apoyo a la titulación.

Prioridad: Could

Fuente: Migración `V23__orientacion_semilla_recursos_titulacion.sql`.

Endpoint: `GET/api/v1/orientacion/recursos`

Rationale: Los recursos son material de referencia; restringirlos por permiso no aportaría protección y sí fricción.

Criterio de aceptación:

- Responde 200 con los recursos vigentes a cualquier usuario autenticado.
- Sin autenticación responde 401.

Método de verificación: Prueba

Estado: **Verificado**

RF-51 Ruta de progreso de titulación

Enunciado: El sistema debe presentar al estudiante los ocho pasos de la ruta de titulación, permitirle marcar los completados, y calcular el porcentaje de avance.

Prioridad: Should

Fuente: `docs/funcionalidades/CENTRO-ORIENTACION.md` y migración `V20`, que define el catálogo de pasos de la ruta de titulación.

Endpoints: `GET/api/v1/orientacion/progreso`, `PUT/api/v1/orientacion/progreso`

Rationale: Traduce un proceso administrativo largo en una lista concreta de pasos, que es lo que el estudiante necesita para saber qué le falta sin interpretar estados internos.

Criterio de aceptación:

- El catálogo de pasos es cerrado y ordenado: tema definido, tutor asignado, anteproyecto elaborado, anteproyecto aprobado, solicitud registrada, correcciones aplicadas, documento final y pre-sustentación programada.
- El porcentaje es el número de pasos completados sobre el total, redondeado al entero más próximo.
- Un usuario cuyo rol no es ESTUDIANTE responde 403.
- La consulta y la actualización operan exclusivamente sobre el progreso del estudiante en sesión.

Método de verificación: Prueba

Estado: **Verificado**

Nota: Los ocho pasos se marcan manualmente y no se derivan del estado real de la solicitud (sección 5), de modo que la ruta y el expediente pueden discrepar. La sincronización automática queda como deuda declarada (§13).

7.10. Catálogos académicos y directorio

RF-52 Gestión de catálogos académicos

Enunciado: El sistema debe permitir a quien posea el permiso `CARRERAS_GESTIONAR` crear, editar y eliminar facultades, carreras, modalidades de titulación y períodos académicos.

Prioridad: Must

Fuente: Migración `V17__gestion_carreras.sql`, que crea el permiso `CARRERAS_GESTIONAR` y lo reserva al Administrador.

Endpoints: `POST|PUT|DELETE/api/catalogos/facultades`, `POST|PUT|DELETE/api/catalogos/carreras`, `POST|PUT|DELETE/api/catalogos/modalidades`, `POST|PUT|DELETE/api/catalogos/periodos-academicos`

Rationale: Son los datos maestros de los que cuelgan la solicitud, el estudiante y la convocatoria. Sin ellos el sistema no puede recibir una sola solicitud.

Criterio de aceptación:

- Sin el permiso `CARRERAS_GESTIONAR` las doce operaciones responden 403. La consulta permanece abierta a cualquier usuario autenticado (RF-53).
- Un código duplicado dentro del mismo catálogo responde 400.
- Eliminar un elemento referenciado por solicitudes, estudiantes o convocatorias responde 400 en vez de dejar referencias huérfanas.
- Toda alta, modificación y baja queda registrada en la bitácora de auditoría con su actor (RNF-18).

Método de verificación: Prueba

Estado: **Verificado**

Nota: El Coordinador **no** posee este permiso, pese a que la tabla de actores de la especificación anterior le atribuía la gestión de catálogos. La tabla de la sección 3.2 queda corregida en consecuencia:

la gestión de datos maestros es exclusiva del Administrador (sección 6.4, punto 1).

RF-53 Consulta de catálogos de apoyo

Enunciado: El sistema debe ofrecer a cualquier usuario autenticado la consulta de modalidades, líneas de investigación, áreas temáticas, convocatorias, la convocatoria activa, carreras, períodos académicos y facultades.

Prioridad: Should

Fuente: HU-02 (los catálogos alimentan el formulario de solicitud)

Endpoints: GET/api/catalogos/modalidades, GET/api/catalogos/lineas-investigacion, GET/api/catalogos/areas-tematicas, GET/api/catalogos/convocatorias, GET/api/catalogos/convocatoria-activa, GET/api/catalogos/carreras, GET/api/catalogos/periodos-academicos, GET/api/catalogos/facultades

Rationale: Son los valores admisibles que RF-13 valida. Exponerlos como consulta abierta al usuario autenticado evita que el cliente los duplique en código y se desincronicen.

Criterio de aceptación:

- Las ocho consultas responden 200 a cualquier usuario autenticado.
- La consulta de convocatoria activa devuelve 404 si no hay ninguna activa, en vez de una lista vacía que pueda confundirse con «no hay convocatorias».
- Las áreas temáticas admiten filtrado por línea de investigación.

Método de verificación: Prueba

Estado: Verificado

RF-54 Gestión de estudiantes

Enunciado: El sistema debe permitir a quien posea el permiso ESTUDIANTES_GESTIONAR registrar y editar el perfil académico de un estudiante —carrera, semestre, período de ingreso y estado académico— y consultarlo de forma paginada.

Prioridad: Must

Fuente: Migración V16__gestion_estudiantes.sql, que crea el permiso ESTUDIANTES_GESTIONAR y el catálogo de estados académicos.

Endpoints: GET/api/estudiantes/paginado, GET/api/estudiantes/{id}, POST/api/estudiantes, PUT/api/estudiantes/{id}, GET/api/estudiantes/estados-academicos

Rationale: El perfil de estudiante es distinto de la cuenta de usuario: una cuenta identifica a una persona, el perfil la sitúa en una carrera y un período, que es lo que la solicitud necesita.

Criterio de aceptación:

- Sin el permiso ESTUDIANTES_GESTIONAR las cinco operaciones responden 403.

- El estado académico pertenece al conjunto cerrado **ACTIVO**, **EGRESADO**, **GRADUADO**, **RETIRADO**, **SUSPENDIDO**; cualquier otro responde 400.
- Un usuario solo puede tener un perfil de estudiante; un segundo registro responde 400.
- El alta genera el código de expediente del estudiante, único en el sistema.
- Toda alta y modificación queda registrada en la bitácora de auditoría (RNF-18).

Método de verificación: Prueba

Estado: **Verificado**

RF-55 Consulta del directorio de docentes

Enunciado: El sistema debe permitir a cualquier usuario autenticado consultar los docentes, de forma completa, paginada, por identificador, por usuario asociado y filtrando los disponibles para asignación.

Prioridad: Should

Fuente: HU-03 (la asignación de tutor y tribunal necesita el directorio)

Endpoints: GET/api/docentes, GET/api/docentes/paginado, GET/api/docentes/disponibles, GET/api/docentes/{id}, GET/api/docentes/usuario/{usuarioId}

Rationale: El filtro de disponibles es el que hace utilizable la asignación de RF-22 y RF-27: sin él, la coordinación descubre la indisponibilidad al recibir el rechazo.

Criterio de aceptación:

- El listado de disponibles excluye a los docentes marcados como no disponibles, que son exactamente los que RF-27 rechaza.
- Ninguna respuesta incluye la contraseña almacenada del usuario asociado.
- Sin autenticación responde 401.

Método de verificación: Prueba

Estado: **Verificado**

7.11. Reportes, observaciones y auditoría

RF-56 Reportes de gestión

Enunciado: El sistema debe ofrecer a quien posea el permiso **REPORTES_VER** los indicadores de resumen, solicitudes por estado, sustentaciones por período, actas, actividad docente, resultados por carrera, defensas programadas y estadísticas generales.

Prioridad: Should

Fuente: HU-09, CU-09

Endpoints: GET/api/reportes/resumen, GET/api/reportes/solicitudes-por-estado, GET/api/reportes/sustentaciones-por-periodo, GET/api/reportes/actas, GET/api/reportes/acti

vidad-docente, GET/api/reportes/por-carrera, GET/api/reportes/defensas, GET/api/reportes/estadisticas/json

Rationale: Es la vista agregada con la que la coordinación decide. Los reportes cruzan calificaciones y actividad docente nominal, así que su control de acceso importa tanto como su contenido.

Criterio de aceptación:

- Las ocho consultas responden 200 para ADMIN y COORDINADOR, y 403 para DOCENTE y ESTUDIANTE.
- Las cifras agregadas coinciden con el conteo por estado de RF-18 sobre los mismos datos.
- Los estados usados en los agregados son exclusivamente los de la sección 5.

Método de verificación: Prueba + Demostración

Estado: **Verificado**

RF-57 Emisión de reportes en PDF

Enunciado: El sistema debe emitir en formato PDF el reporte de cronograma y el reporte de estadísticas, a quien posea el permiso REPORTES_VER.

Prioridad: Should

Fuente: HU-09, CU-09

Endpoints: GET/api/reportes/cronograma/pdf, GET/api/reportes/estadisticas/pdf

Rationale: Los reportes se archivan y se firman fuera del sistema; un PDF es el formato que la coordinación puede adjuntar a un expediente físico.

Criterio de aceptación:

- Responde 200 con tipo de contenido application/pdf y el nombre de archivo en la cabecera de disposición de contenido.
- Sin el permiso REPORTES_VER responde 403.
- El PDF refleja los mismos datos que el reporte equivalente de RF-56 en el mismo instante.

Método de verificación: Prueba + Demostración

Estado: **Verificado**

RF-58 Estadísticas de acompañamiento por tutor

Enunciado: El sistema debe ofrecer las estadísticas de acompañamiento de los tutores —estudiantes asignados y estado de sus tutorías— a quien esté habilitado para ello.

Prioridad: Could

Fuente: ADR-006 y docs/basedatos/CATALOGO-SP.md: el procedimiento almacenado sp_obtener_estadisticas_tutores existe para resolver esta consulta en la base de datos.

Endpoint: GET/api/tutores/estadisticas

Rationale: Permite a la coordinación detectar tutorías detenidas antes de que bloqueen la conformación del tribunal, que es donde el retraso se vuelve visible y ya es tarde.

Criterio de aceptación:

- Responde 200 con el número de estudiantes asignados y el estado de las tutorías por tutor.
- Sin el permiso exigido responde 403.

Método de verificación: Prueba**Estado:** **Implementado**

Nota: Este endpoint se protege hoy con `EVALUACION_RUBRICA_REGISTRAR`, un permiso de la categoría Evaluación que no describe esta capacidad y que además poseen los docentes. La asimetría es real y queda como deuda declarada: el permiso adecuado sería `REPORTES_VER` o uno propio de tutoría (§13).

RF-59 Consulta de observaciones de la solicitud

Enunciado: El sistema debe permitir consultar las observaciones registradas sobre una solicitud a los actores con derecho sobre ese expediente.

Prioridad: Could

Fuente: HU-02 y migración `V1__schema_inicial.sql` (campo `observaciones` de la solicitud), que es donde se acumulan las observaciones que RF-15, RF-21 y RF-25 producen en momentos distintos.

Endpoint: `GET/api/observaciones/solicitud/{solicitudId}`

Rationale: Reúne en un solo lugar las observaciones que RF-15, RF-21 y RF-25 producen en momentos distintos del proceso.

Criterio de aceptación:

- Consultar las observaciones de una solicitud ajena responde 403.
- Una solicitud sin observaciones responde 200 con una colección vacía.

Método de verificación: Prueba**Estado:** **Implementado**

RF-60 Consulta de la bitácora de auditoría

Enunciado: El sistema debe permitir a quien posea el permiso `AUDITORIA_VER` consultar de forma paginada la bitácora de acciones registradas y la lista de tablas auditadas.

Prioridad: Must

Fuente: Criterio de auditoría de la asignatura; OWASP A09

Endpoints: `GET/api/auditoria/paginado`, `GET/api/auditoria/tablas`

Rationale: Registrar acciones y poder consultarlas son capacidades distintas con controles de acceso distintos. RNF-18 obliga a registrar; este requisito obliga a que exista una vía de consulta y a que esté restringida, porque la bitácora contiene datos personales de todos los usuarios.

Criterio de aceptación:

- Sin el permiso `AUDITORIA_VER` responde 403; el permiso es exclusivo del Administrador (sección 6.4, punto 2).
- La consulta paginada acepta filtro por tabla y por rango de fechas.
- Ninguna entrada devuelta expone la contraseña almacenada de un usuario, ni siquiera en el registro de cambios de la tabla de usuarios.
- La bitácora no ofrece ninguna operación de modificación ni de borrado por API.

Método de verificación: Prueba + Inspección

Estado: **Verificado**

Depende de: RNF-18, RNF-19

7.12. Continuidad: respaldo y recuperación

RF-61 Respaldo de la base de datos bajo demanda y programado

Enunciado: El sistema debe permitir a quien posea el permiso `BACKUPS_GESTIONAR` generar respaldos completos bajo demanda, generar respaldos diferenciales, ejecutarlos automáticamente según un cronograma configurable, y listarlos y descargarlos.

Prioridad: Must

Fuente: docs/despliegue/BACKUP.md, criterio de continuidad de la asignatura, y migración V27_
_permiso_gestion_respaldos.sql.

Endpoints: GET/api/backups, POST/api/backups, POST/api/backups/diferencial, GET/api/backups/{nombre}/descargar, DELETE/api/backups/{nombre}, GET/api/backups/estado, POST/api/backups/bases, DELETE/api/backups/bases/{nombre}

Rationale: Un respaldo que nadie puede generar ni descargar no protege nada. El respaldo es además el único mecanismo del sistema capaz de recuperar un expediente académico perdido, de modo que su prioridad no es negociable.

Criterio de aceptación:

- Sin el permiso `BACKUPS_GESTIONAR` las ocho operaciones responden 403; el permiso es exclusivo del Administrador.
- Si el respaldo termina sin error pero produce un archivo vacío, la operación responde 500 declarándolo; **nunca se registra como respaldo válido**.
- Un nombre de respaldo que no corresponda al formato esperado responde 400, y en ningún caso permite acceder a una ruta fuera del directorio de respaldos.
- El listado informa por cada respaldo su tipo, su origen, su fecha y su tamaño.

Método de verificación: Demostración + Inspección

Estado: **Verificado**

Depende de: RNF-24

RF-62 Configuración del cronograma y de la retención de respaldos

Enunciado: El sistema debe permitir consultar y modificar el cronograma de respaldos, su activación y su política de retención, y aplicar la retención bajo demanda.

Prioridad: Should

Fuente: docs/despliegue/BACKUP.md y migración V28__gestion_respalDOS_cronograma.sql, que persiste el cronograma y la política de retención como configuración.

Endpoints: GET/api/backups/config, PUT/api/backups/config, POST/api/backups/retencion

Rationale: La retención es lo que separa un directorio que crece sin límite de una política de continuidad. Fijarla como configuración, y no en código, permite ajustarla al crecimiento real sin desplegar.

Criterio de aceptación:

- La configuración por omisión es: respaldo completo los domingos a las 23:00; retención de 7 diarios, 5 semanales y 12 mensuales; 14 días de archivado WAL; diferencial desactivado.
- Una expresión de cronograma inválida responde 400 nombrando el valor recibido y el formato esperado, y **no** se guarda ninguna parte del cambio.
- La consulta de configuración informa el próximo disparo calculado y el objetivo de punto de recuperación que ese cronograma implica.
- Todo cambio de configuración registra qué usuario lo realizó y cuándo.

Método de verificación: Demostración + Inspección

Estado: **Implementado**

Depende de: RNF-24

RF-63 Restauración y prueba de restauración

Enunciado: El sistema debe permitir restaurar un respaldo y ejecutar una prueba de restauración que verifique que el respaldo es recuperable, registrando su resultado.

Prioridad: Must

Fuente: docs/despliegue/BACKUP.md y migración V29__respaldos_fase2_wal_diferencial.sql, que registra el resultado de cada prueba de restauración.

Endpoints: POST/api/backups/{nombre}/restaurar, GET/api/backups/pruebas, POST/api/backups/pruebas

Rationale: Un respaldo no probado es una suposición. La prueba periódica es la única forma de saber que el respaldo servirá el día que haga falta, y su registro es la evidencia de que se hizo.

Criterio de aceptación:

- La prueba de restauración registra su resultado como **EXITOSA** o **FALLIDA**, con fecha, y ese registro es consultable.
- La prueba de restauración **no** altera la base de datos en servicio.
- Sin el permiso **BACKUPS_GESTIONAR** las tres operaciones responden 403.
- Una restauración fallida deja el sistema en un estado consistente y declara el motivo, en vez de dejar la base parcialmente sobrescrita.

Método de verificación: Demostración

Estado: **Verificado**

Depende de: RNF-24

RF-64 Archivado WAL y recuperación a un punto en el tiempo

Enunciado: El sistema debe permitir consultar el estado del archivado del registro de escritura anticipada, forzar su rotación y depurar los segmentos que superen el período de retención configurado.

Prioridad: Should

Fuente: docs/despliegue/BACKUP.md y migración V29__respaldos_fase2_wal_diferencial.sql.

Endpoints: GET/api/backups/wal, POST/api/backups/wal/switch, POST/api/backups/wal/limpiar

Rationale: Es lo que hace posible recuperar a un instante distinto del último respaldo completo, y por tanto lo que determina el objetivo de punto de recuperación real de RNF-24. Sin depuración, el archivado crece hasta agotar el disco.

Criterio de aceptación:

- La consulta informa el número de segmentos archivados, su tamaño total y el segmento más antiguo disponible.
- La depuración elimina exclusivamente los segmentos anteriores al período de retención configurado en RF-62, y nunca los necesarios para recuperar el respaldo completo más reciente.
- Sin el permiso **BACKUPS_GESTIONAR** las tres operaciones responden 403.

Método de verificación: Demostración

Estado: **Implementado**

Depende de: RNF-24

8. Requisitos no funcionales

Los requisitos de esta sección usan la misma plantilla que los funcionales. Su fuente es, en la mayoría de los casos, una decisión de arquitectura o una norma externa y no una historia de usuario; se declara explícitamente cuál en vez de dejar el campo vacío.

8.1. Rendimiento y eficiencia

RNF-01 Tiempo de respuesta de la API

Enunciado: El sistema debe responder las peticiones REST con un percentil 95 de latencia inferior a 500 ms bajo una carga de 50 usuarios concurrentes.

Prioridad: Must

Fuente: Criterio de rendimiento de la asignatura

Rationale: Fija un umbral exigible y no una aspiración: sin umbral, ningún requisito se incumpliría aunque la latencia subiera un orden de magnitud.

Criterio de aceptación: El percentil 95 de `http_req_duration` debe ser inferior a 500 ms en cada una de al menos 5 corridas independientes de carga con 50 usuarios virtuales concurrentes, con los resúmenes crudos archivados en el repositorio.

Método de verificación: Análisis

Estado: **Verificado**

Evidencia: 5 corridas válidas con p95 de 7,70 / 7,39 / 7,47 / 8,53 / 6,17 ms; media **7,45 ms** (`k6/README.md`, corridas 3 a 7; las dos últimas del 2026-08-29). Dos corridas anteriores se conservan versionadas y **marcadas como inválidas**, y no entran en la estadística.

RNF-02 Rendimiento percibido del cliente web

Enunciado: El sistema debe alcanzar una puntuación de rendimiento igual o superior a 80 sobre 100 en la auditoría automatizada del cliente web, en perfil de escritorio y de móvil.

Prioridad: Should

Fuente: Criterio de calidad de frontend de la asignatura

Rationale: RNF-01 mide el servicio, no lo que el usuario percibe. Un servicio de 7 ms puede seguir sintiéndose lento si el cliente tarda seis segundos en pintar.

Criterio de aceptación: Puntuación de rendimiento ≥ 80 en las corridas de escritorio y de móvil sobre el build de producción, con los informes archivados y fechados.

Método de verificación: Análisis

Estado: **No cumplido**

Evidencia: Medición del 2026-09-06, 6 corridas: escritorio **68–69**, móvil **61**. Causa raíz identificada y verificada: tiempo de ejecución de JavaScript bajo la limitación de CPU 4× del perfil móvil, no peso de recursos.

Nota: Se declara **No cumplido** y no «pendiente de evidencia»: la medición existe y el resultado no alcanza el umbral. Bajar el umbral para que cuadre sería falsear el requisito. El plan de cierre está en §13.

RNF-03 Caché de lectura con vigencia acotada

Enunciado: El sistema debe cachear en memoria distribuida las lecturas de alto tráfico y la respuesta del proveedor externo, con un tiempo de vigencia declarado por cada conjunto de datos.

Prioridad: Should

Fuente: ADR-001

Rationale: La diferencia medida entre caché fría y caliente en el endpoint externo es de dos órdenes de magnitud; la vigencia acotada es lo que impide servir datos obsoletos a cambio de esa ganancia.

Criterio de aceptación: Vigencia por omisión de **5 minutos**; **10 minutos** para el directorio externo de RF-45 y **5 minutos** para el listado de solicitudes. Vencida la vigencia, la siguiente lectura debe consultar el origen.

Método de verificación: Análisis + Inspección

Estado: **Verificado**

Evidencia: Caché fría $n = 30$: media 109,62 ms, IC 95 % [102,57; 116,67]. Caché caliente $n = 30$: IC 95 % [7,58; 8,14]. Prueba de Wilcoxon con $U = 0$ sobre 900 comparaciones posibles: separación total (k6/README.md).

RNF-04 Degradación explícita ante indisponibilidad de la caché distribuida

Enunciado: Cuando el almacén de sesión distribuido no esté disponible, el sistema debe degradar de forma explícita y documentada en cada servicio que depende de él, y en particular debe **rechazar** toda petición cuya verificación de revocación de token no pueda realizarse.

Prioridad: Must

Fuente: ADR-002; OWASP A07

Rationale: La verificación de revocación (RF-03) y el límite de tasa (RNF-09) se apoyan en ese almacén. Si su caída se resuelve dejando pasar la petición, cerrar sesión deja de revocar nada y el límite de tasa desaparece exactamente cuando la infraestructura está degradada, que es el peor momento posible. La política es una decisión de seguridad, no un detalle de infraestructura, y por eso es un requisito y no una nota de riesgo.

Criterio de aceptación:

- **Revocación de tokens:** con el almacén caído, una petición autenticada responde 401, no 200.
- **Límite de tasa de autenticación:** con el almacén caído, el intento de autenticación responde 503 declarando la degradación, no 500 ni acceso sin límite.
- **Caché de lectura:** con el almacén caído, la lectura se resuelve contra el origen y la respuesta se sirve igualmente; es el único servicio donde se admite seguir adelante.
- Cada degradación deja una entrada de registro que la identifica.

Método de verificación: Prueba

Estado: **Verificado**

Nota: Cerrado en la fase 4 (2026-09-11): `JwtTokenProvider.isTokenBlacklisted()` y `RateLimiterService.isAl` distinguen ahora una excepción de acceso al almacén (`DataAccessException` y afines) de un problema del propio token o de una entrada normal, y fallan **cerrado** (401 / 503) solo ante la primera. La caché de lectura usa un `CacheErrorHandler` dedicado que absorbe el error y dejar seguir el método hacia el origen – la única de las tres que falla **abierto**, a propósito. Las tres rutas registran una entrada identificable (`DEGRADACION (RNF-04): ...`). Verificado con `RedisDegradacionTest.java`, doble de `StringRedisTemplate` que lanza `RedisConnectionFailureException`.

8.2. Seguridad

RNF-05 Almacenamiento de contraseñas

Enunciado: El sistema debe almacenar las contraseñas mediante una función de derivación de clave con salto aleatorio y factor de coste igual o superior a 10, y no debe devolver nunca la contraseña almacenada en ninguna respuesta.

Prioridad: Must

Fuente: OWASP A02; ADR-004

Rationale: Es la única defensa que queda en pie si la base de datos se filtra.

Criterio de aceptación: Ningún registro de usuario contiene la contraseña en claro; dos usuarios con la misma contraseña producen representaciones almacenadas distintas; ningún cuerpo de respuesta de RF-01, RF-04, RF-08 ni RF-55 incluye ese campo.

Método de verificación: Prueba + Inspección

Estado: **Verificado**

RNF-06 Política de contraseñas

Enunciado: El sistema debe exigir a toda contraseña una longitud mínima de 8 caracteres y rechazar las que figuren en una lista de contraseñas comunes, aplicando la misma exigencia en el alta, en el cambio y en el restablecimiento.

Prioridad: Must

Fuente: OWASP A07; NIST SP 800-63B

Rationale: RNF-05 especifica cómo se guarda la contraseña, no qué se exige de ella. Almacenar impecablemente una contraseña de seis caracteres no protege la cuenta.

Criterio de aceptación: Una contraseña de menos de 8 caracteres responde 400 en el alta (RF-04), en el cambio (RF-06) y en el restablecimiento (RF-05); la respuesta declara la regla incumplida sin revelar la contraseña.

Método de verificación: Prueba

Estado: **Verificado**

Nota: Cerrado en los tres puntos de aplicación que el criterio exige, con el mismo `PasswordPolicyValidator` reutilizable (respaldado por `backend/src/main/resources/security/common-passwords.txt`) en los tres: el alta (RF-04, fase 3), el cambio propio (RF-06, fase 5) y el restablecimiento (RF-05, fase 6). Nota aparte sobre RF-05: se declara **Implementado** y no **Verificado** por un motivo distinto a este requisito – la entrega real del correo por SMTP nunca se verificó – pero la aplicación de esta política dentro de ese flujo sí es real y está probada (`PasswordRecoveryServiceTest`), independientemente de si el correo llega.

RNF-07 Vigencia de los tokens de sesión

Enunciado: El token de acceso debe tener una vigencia de 1 hora y el token de renovación una vigencia de 7 días, ambas configurables por variable de entorno sin recompilar.

Prioridad: Must

Fuente: ADR-002

Rationale: Estos dos valores son normativos: acotan la ventana de uso de una credencial robada. Hasta esta versión estaban únicamente en un archivo de configuración, es decir, eran valores normativos escondidos fuera de la especificación.

Criterio de aceptación: El token de acceso expira a los **3 600 000 ms** y el de renovación a los **604 800 000 ms**; un token de acceso expirado responde **401** con un mensaje que el cliente pueda distinguir de «sin permiso».

Método de verificación: Prueba + Inspección

Estado: **Verificado**

RNF-08 Rotación del token de renovación y detección de reutilización

Enunciado: Cada uso de un token de renovación debe invalidarlo y emitir uno nuevo, y la presentación de un token ya utilizado debe revocar todas las sesiones activas de ese usuario.

Prioridad: Must

Fuente: ADR-002; OWASP A07

Rationale: Es lo que convierte el robo de un token de renovación en un evento detectable en vez de un acceso silencioso durante siete días.

Criterio de aceptación: El criterio observable es el de RF-02; adicionalmente, la revocación masiva debe dejar sin efecto **todos** los tokens de renovación del usuario, no solo el reutilizado, y registrar una alerta identificando al usuario afectado.

Método de verificación: Prueba

Estado: **Verificado**

RNF-09 Límite de tasa en la autenticación

Enunciado: El sistema debe limitar los intentos de autenticación a un máximo de 6 por minuto y por dirección de origen, respondiendo 429 al superarlo.

Prioridad: Must

Fuente: OWASP A07; ADR-004

Rationale: Sin límite, la política de contraseñas de RNF-06 se puede vencer por fuerza bruta en línea con independencia de su robustez.

Criterio de aceptación: El séptimo intento dentro de una ventana de **60 segundos** desde la misma dirección responde 429; el contador expira solo al cerrarse la ventana; detrás de un proxy inverso se considera la dirección de origen real declarada por el proxy y no la del proxy.

Método de verificación: Prueba + Análisis

Estado: Verificado

Evidencia: Corrida dedicada archivada en `k6/rate-limiter-evidence-run.json`.

Depende de: RNF-04

RNF-10 Cabeceras de seguridad HTTP

Enunciado: Toda respuesta del sistema debe incluir las cabeceras de seguridad que restringen el origen de los recursos ejecutables, prohíben el enmarcado de la aplicación, impiden la interpretación especulativa del tipo de contenido y exigen transporte cifrado.

Prioridad: Must

Fuente: OWASP A05; ADR-004

Rationale: Son la defensa en profundidad que sigue actuando cuando falla una validación de entrada.

Criterio de aceptación:

- `Strict-Transport-Security` con vigencia de **31 536 000 s** e inclusión de subdominios.
- `Content-Security-Policy` con `script-src 'self'`, sin `'unsafe-inline'` ni `'unsafe-eval'`, `connect-src 'self'` y `frame-ancestors 'none'`.
- `X-Frame-Options`: DENY y `X-Content-Type-Options`: nosniff.
- Las mismas cabeceras se emiten en las **dos** capas que responden al navegador: el proxy inverso y el servicio de aplicación.

Método de verificación: Análisis + Inspección

Estado: Verificado

Evidencia: Escaneo dinámico del 2026-08-29: FAIL-NEW: 0, WARN-NEW: 3, PASS: 58, **0 alertas de riesgo alto**. Verificación con petición de cabeceras transcrita en `docs/mediciones/sec/owasp/OWASP-AUDIT.md`.

RNF-11 Transporte cifrado

Enunciado: En despliegue accesible desde fuera de la red local, todo tráfico debe viajar sobre TLS 1.2 o superior, con certificado válido emitido por una autoridad reconocida, y las peticiones en claro deben redirigirse a su equivalente cifrada.

Prioridad: Must

Fuente: OWASP A02; ADR-007

Rationale: La cabecera de transporte estricto de RNF-10 solo tiene efecto si existe realmente un extremo cifrado; declararla sin TLS es una promesa vacía.

Criterio de aceptación: Sobre el despliegue público: la conexión negocia TLS 1.2 o superior, el certificado valida contra la cadena pública, una petición en claro responde con redirección permanente a la versión cifrada, y la cabecera de transporte estricto se emite en la respuesta cifrada.

Método de verificación: Demostración sobre el despliegue público

Estado: Planificado

Nota: El sistema **no está desplegado públicamente** en el punto de corte, de modo que este requisito no puede verificarse todavía. El proveedor elegido y el procedimiento están en `docs/despliegue/DEPLOYMENT.md`. La terminación TLS ocurrirá en el borde del proveedor, no en el proxy inverso del sistema; ese reparto debe quedar declarado aquí cuando el despliegue exista. No se declara una URL ni un certificado que no se hayan verificado funcionando.

RNF-12 Autorización resuelta en el servidor

Enunciado: Toda decisión de autorización debe resolverse en el servidor contra el catálogo de permisos del rol del usuario en sesión, y **nunca** a partir de un rol, permiso o identificador enviado por el cliente.

Prioridad: Must

Fuente: OWASP A01; ADR-005

Rationale: Es la propiedad que sostiene toda la matriz de la sección 6. Si el rol pudiera llegar en el cuerpo de la petición, esa matriz sería decorativa.

Criterio de aceptación: Una petición que declare en su cuerpo o en sus cabeceras un rol o un permiso distinto del que el usuario en sesión posee obtiene exactamente la misma respuesta que si no lo declarara; una petición sin autenticación a un endpoint protegido responde 401 y una autenticada sin permiso responde 403, y ambos casos son distinguibles por el cliente.

Método de verificación: Prueba + Inspección

Estado: Verificado

RNF-13 Aislamiento de los datos por titular

Enunciado: El sistema debe rechazar todo acceso a un recurso que no pertenezca al usuario en sesión ni corresponda a un rol funcional que este ejerza sobre ese recurso, aunque se conozca su identificador.

Prioridad: Must

Fuente: OWASP A01; 3 hallazgos reales de la auditoría del 2026-08-11/12

Rationale: Es el control que impide que conocer un número de expediente equivalga a poder leerlo. Se especifica una vez y se referencia desde cada requisito afectado, en vez de repetir la regla en veinte criterios de aceptación.

Criterio de aceptación: Para cada uno de los recursos solicitud, anteproyecto, fase de tutoría, evaluación, acta, historial de acta, notificación y perfil, una petición de un usuario sin derecho sobre ese recurso responde 403 conociendo su identificador, y la respuesta no revela si el recurso existe.

Método de verificación: Prueba + Demostración

Estado: Verificado

RNF-14 Ausencia de secretos por omisión

Enunciado: El sistema no debe arrancar si el secreto de firma de tokens no está provisto por el entorno, y no debe existir ningún valor por omisión para ese secreto.

Prioridad: Must

Fuente: OWASP A02; hallazgo real de la auditoría del 2026-08-29

Rationale: Un valor por omisión convierte el secreto en público: la auditoría encontró que el anterior era un secreto de ejemplo que circula en tutoriales. Fallar al arrancar es preferible a arrancar con una firma que cualquiera puede reproducir.

Criterio de aceptación: Sin la variable de entorno del secreto, el arranque falla con un error explícito y el servicio no queda a la escucha; el secreto no aparece en ningún registro ni en ninguna respuesta.

Método de verificación: Inspección + Demostración

Estado: Verificado

RNF-15 Ausencia de cuentas de demostración en despliegue no local

Enunciado: El sistema no debe sembrar cuentas con contraseña predefinida fuera del perfil de desarrollo local, y ninguna contraseña debe figurar literalmente en el código fuente.

Prioridad: Must

Fuente: OWASP A05 y A07; **observación docente OBS-11** (`docs/observaciones/OBSERVACIONES.md`), registrada como *resuelta* desde la fase 4 (2026-09-11): los seis artefactos que repetían la credencial, incluido el origen en código, quedan corregidos.

Rationale: Una cuenta de administración con contraseña conocida es equivalente a no tener autenticación. El repositorio es público, de modo que cualquier contraseña escrita en cualquier archivo versionado está publicada, y el historial de Git conserva lo que se retire hoy. OBS-11 ya identificó el problema; convertirlo en requisito con criterio verificable es lo que le puso condición de cierre a una observación que llevó meses en estado parcial.

Criterio de aceptación:

- La siembra de datos de demostración se ejecuta **únicamente** bajo un perfil de desarrollo declarado, y no en el arranque por omisión.
- Ninguna contraseña aparece literalmente en el código fuente; las cuentas iniciales de un despliegue real toman su contraseña del entorno.
- Un despliegue no local sin cuenta de administración provista falla al arrancar en vez de crear una con contraseña conocida.
- **Ninguna credencial de ejemplo aparece en ningún artefacto versionado.** Una búsqueda de la contraseña sembrada sobre el árbol completo del repositorio —código, documentación, historias de usuario, colección de peticiones y ficheros de configuración— devuelve cero coincidencias.
- Los artefactos que necesitan una credencial para ser ejecutables (la colección de peticiones de la API, los ejemplos de las historias de usuario) la toman de una variable de entorno o de un marcador de posición, nunca de un valor literal.

Método de verificación: Inspección + Demostración

Estado: **Verificado**

Nota: Inventario completo (verificado el 2026-09-11). La credencial sembrada aparecía en seis artefactos versionados del repositorio público: el código que siembra los datos de demostración, la colección de peticiones de `docs/postman/`, el escenario de ejemplo de `docs/requisitos/historias/HU-01.md`, el procedimiento de medición de `k6/README.md`, la evidencia reproducible de `docs/mediciones/sec/owasp/OWASP-AUDIT.md` y el propio registro de OBS-11. Los cinco artefactos de documentación se corrigieron primero (toman la credencial de una variable de entorno o de una variable de colección); el origen —el código— se cierra en esta fase: la siembra se movió a `DemoDataSeeder`, activo **solo** bajo el perfil `dev` (nunca en el arranque por omisión); sus contraseñas se rotaron y ya cumplen RNF-06; y un despliegue fuera de ese perfil sin `ADMIN_BOOTSTRAP_EMAIL/ADMIN_BOOTSTRAP_PASSWORD` en el entorno falla al arrancar en `AdminBootstrap` en vez de crear una cuenta con contraseña conocida —mismo patrón que `JWT_SECRET` (RNF-14)—, y la contraseña que sí se provee se valida contra `PasswordPolicyValidator` (RNF-06) antes de usarse. Verificado a mano arrancando sin perfil `dev` y sin las variables (falla explícitamente), con una contraseña de la lista de comunes (también falla) y con una contraseña válida (arranca y crea la cuenta). `grep -rn .^admin123\|docente123\|estudiante123-include=*.java -include=*.md -include=*.json -include=*.yaml .` (excluyendo `docs/requisitos/historico/`) da cero resultados.

Lo que sigue abierto, y por qué (sin cambios respecto a la versión anterior de esta nota). La migración `V11__roles_y_privilegios.sql` crea dos roles de base de datos con contraseña literal; una migración ya aplicada no se puede editar sin romper la suma de verificación de Flyway, así que cerrarla exige una migración nueva que las rote, no una corrección en su sitio – deliberadamente sin tocar en esta fase. Y esto no lo arregla ningún cambio de código: **el historial de Git conserva las contraseñas retiradas hoy** (incluidas las que `DemoDataSeeder` sembraba antes de esta fase), de modo que deben considerarse comprometidas y rotarse en cualquier despliegue real; no se reescribe el historial para ocultarlas.

RNF-16 Ausencia de construcción dinámica de consultas

Enunciado: El sistema no debe construir sentencias SQL por concatenación de valores provenientes de la entrada del usuario.

Prioridad: Must

Fuente: OWASP A03; ADR-006

Rationale: La estrategia híbrida de ADR-006 reparte la lógica entre el mapeador objeto-relacional y procedimientos almacenados, y ninguno de los dos caminos admite concatenar entrada del usuario. Verificarlo con una herramienta en cada integración, y no por revisión manual, es lo que impide que una consulta construida a mano se cuele en una entrega futura.

Criterio de aceptación: El análisis estático del backend, con la regla de detección de SQL dinámico habilitada, reporta **0** hallazgos de esa categoría en cada corrida archivada.

Método de verificación: Análisis

Estado: **Verificado**

Evidencia: Análisis estático del 2026-08-29: 233 hallazgos totales, **0** de SQL dinámico (`docs/mediciones/sec/static-analysis/STATIC-ANALYSIS.md`).

RNF-17 Gestión de componentes de terceros vulnerables

Enunciado: El sistema no debe entregar al navegador ningún componente de terceros con vulnerabilidad conocida de severidad alta o crítica, y debe auditar sus dependencias en cada integración continua.

Prioridad: Should

Fuente: OWASP A06

Rationale: Distingue lo que llega al navegador de lo que solo se usa para construir el proyecto: son superficies de ataque distintas y confundirlas lleva a inflar o a minimizar el riesgo.

Criterio de aceptación: Cero vulnerabilidades altas o críticas en dependencias **enviadas al navegador**; las que residan exclusivamente en herramientas de construcción se declaran, con su recuento y su justificación, en el informe de auditoría.

Método de verificación: Análisis

Estado: **Verificado**

Evidencia: Auditoría del 2026-08-29: la biblioteca de cliente vulnerable se actualizó y la alerta de riesgo alto pasó a conforme; quedan **14** vulnerabilidades (desde 41), todas en herramientas de construcción de iconos. El backend no está auditado contra base de datos de vulnerabilidades, y así se declara.

8.3. Trazabilidad y protección de datos

RNF-18 Registro de auditoría de las acciones

Enunciado: El sistema debe registrar, para cada alta, modificación y baja sobre las entidades auditadas, la tabla, el registro afectado, la acción, el usuario que la realizó y el instante, y ese registro no debe ser modificable ni eliminable desde la aplicación.

Prioridad: Must

Fuente: OWASP A09; criterio de auditoría de la asignatura

Rationale: Una bitácora que la aplicación puede editar no es evidencia. Que la escriba el motor de base de datos, y no la capa de aplicación, es lo que la hace resistente a un fallo o a un atajo del código.

Criterio de aceptación:

- Cada operación auditada produce exactamente una entrada con actor identificado.
- Cuando la operación no proviene de una sesión de usuario, la entrada se registra igualmente con el actor sin identificar, en vez de omitirse.
- La entrada correspondiente a la tabla de usuarios **excluye** el campo de contraseña, tanto en los datos anteriores como en los nuevos.
- No existe ninguna operación de la API que permita modificar o borrar una entrada.

Método de verificación: Inspección + Prueba

Estado: **Verificado**

RNF-19 Retención y supresión de datos personales

Enunciado: El sistema debe declarar el período de conservación de cada categoría de dato personal que trata, depurar automáticamente lo que exceda ese período, y ofrecer un mecanismo de supresión a solicitud del titular compatible con la conservación del expediente académico.

Prioridad: Must

Fuente: Ley Orgánica de Protección de Datos Personales del Ecuador; docs/etica/ETHICS.md

Endpoints: `POST/api/usuarios/{id}/solicitar-supresion`, `GET/api/usuarios/solicitudes-supresion`, `POST/api/usuarios/solicitudes-supresion/{id}/resolver` – la depuración automática de la bitácora no tiene endpoint, por diseño (ver Nota).

Rationale: El sistema trata nombre, correo institucional, teléfono, expediente académico nominal, calificaciones y una bitácora de acciones por usuario. Hoy nada de eso tiene plazo de conservación ni vía de supresión: la bitácora crece indefinidamente y el titular no tiene forma de ejercer sus derechos. Un hallazgo ético sin requisito no tiene fecha de cierre.

Criterio de aceptación:

- Existe una tabla publicada que declara, por categoría de dato, su finalidad, su base legal y su período de conservación.
- Las entradas de bitácora anteriores al período declarado se depuran de forma automática y verificable.
- Existe un procedimiento de supresión a solicitud del titular que distingue el dato suprimible del que la normativa académica obliga a conservar, y deja constancia de la solicitud y de su resolución.
- Los formularios de consentimiento firmados se conservan al menos 2 años, conforme al protocolo ético del proyecto.

Método de verificación: Inspección + Demostración

Estado: **Implementado**

Nota: Construido en la fase 7 (2026-09-11), 3 de 4 criterios – se declara **Implementado** y no **Verificado** porque el criterio exige los cuatro. (1) Tabla de retención publicada en `docs/etica/RETENCION-DATOS.md`, enlazada desde `ETHICS.md`, con período declarado por categoría y una distinción explícita de qué NO es suprimible (expediente académico, calificaciones, actas) por obligación legal de conservación. (2) Depuración automática de la bitácora (`DepuracionBitacoraScheduler`, @Scheduled mensual, retención de 2 años) sin ningún endpoint – resuelve la tensión con RNF-18 (ninguna operación de la API puede borrar la bitácora) a nivel de tarea programada, no de código de aplicación alcanzable por una petición. Deja traza verificable en `presus.depuracion_bitacora_log` (cuántas entradas, hasta qué fecha). (3) Procedimiento de supresión (`SupresionDatosService`) que **seudonimiza**, no borra: el expediente sigue enlazado al mismo id. El registro de la solicitud (`presus.solicitud_supresion`) no guarda el dato suprimido, solo el id del usuario – resolviendo la paradoja de que el registro de una supresión no puede contener lo suprimido. (4) Sin construir de nuevo: los consentimientos firmados conservados ≥ 2 años ya estaban declarados como política en `ETHICS.md` §3 antes de esta fase; no se fabrica ningún formulario firmado que no exista para completar el criterio – sigue siendo, honestamente, una política sin datos reales todavía que aplicarle.

RNF-20 Minimización de datos hacia terceros

Enunciado: El sistema no debe transmitir ningún dato personal de sus usuarios a servicios externos, incluidos proveedores de modelos de lenguaje.

Prioridad: Must

Fuente: Ley Orgánica de Protección de Datos Personales; docs/etica/ETHICS.md

Rationale: Hoy esta propiedad se cumple porque el asistente virtual (RF-44) y la generación de ideas (RF-47) se resuelven dentro del sistema, y porque el único proveedor externo (RF-45) recibe una consulta fija sin parámetros del usuario. Pero eso vive solo en el código: sin requisito, cualquier refactorización futura podría empezar a enviar mensajes de usuarios a un tercero sin que nada lo impida.

Criterio de aceptación:

- La única petición saliente a un tercero es la consulta del directorio de universidades de RF-45, y su contenido no depende de ningún dato del usuario.
- El mensaje que el usuario envía al asistente virtual no sale del sistema.
- Incorporar un proveedor externo nuevo exige declararlo previamente en la sección 4.2 y especificar qué datos concretos viajan.

Método de verificación: Inspección

Estado: **Verificado**

8.4. Mantenibilidad, usabilidad y operación

RNF-21 Cobertura de pruebas automatizadas

Enunciado: El sistema debe mantener una cobertura de pruebas igual o superior al 70 % de líneas y de ramas sobre los paquetes de controladores, servicios y seguridad.

Prioridad: Must

Fuente: Criterio de mantenibilidad de la asignatura

Rationale: El umbral se declara sobre los paquetes donde vive la lógica, y se excluyen configuración, entidades y objetos de transferencia: incluirlos inflaría la cifra sin mejorar la garantía.

Criterio de aceptación: Cobertura ≥ 70 % de líneas y ≥ 70 % de ramas en los paquetes medidos, con el informe crudo archivado y fechado, regenerado en cada integración continua.

Método de verificación: Análisis

Estado: **Verificado**

Evidencia: Medición del **2026-09-06**: **81,03** % de líneas (3 148/3 885) y **64,39** % de ramas (1 016/1 578) en el conjunto; controladores 72,00 %/77,41 % y servicios 87,57 %/70,04 %; 559 pruebas en 48 clases.

Nota: La cobertura de ramas del conjunto (64,39 %) queda por debajo del 70 % aunque cada uno de los dos paquetes principales lo supere; la diferencia proviene de los paquetes de seguridad y enumeraciones. Se declara en vez de reportar solo la cifra de líneas. La versión 1.0.0 de este documento declaraba 38,88 % y «no cumplido»: esa cifra era de una medición del 2026-08-30 que ya estaba obsoleta cuando se publicó.

RNF-22 Usabilidad medida

Enunciado: El sistema debe alcanzar una puntuación media igual o superior a 68 sobre 100 en la escala estándar de usabilidad, aplicada a una muestra declarada de usuarios reales de los cuatro roles.

Prioridad: Should

Fuente: Brooke (1996); docs/etica/ETHICS.md

Rationale: 68 es la media poblacional de referencia del instrumento, de modo que el umbral significa «al menos tan usable como un sistema medio» y no un número elegido para que cuadre.

Criterio de aceptación: Media ≥ 68 sobre una muestra de al menos 10 participantes reales, con el tamaño de muestra, la composición por rol y los datos crudos anonimizados archivados, y consentimiento informado firmado por cada participante.

Método de verificación: Análisis

Estado: Planificado

Nota: El instrumento está listo y no se ha aplicado a personas reales. Una versión anterior del proyecto publicó una media de 91,25 con diez participantes que **nunca existieron**; esos datos fueron retirados y el hecho queda declarado aquí y en docs/mediciones/sus/SUS-RESULTS.md. Se prefiere un requisito sin verificar a una cifra fabricada.

RNF-23 Accesibilidad

Enunciado: El cliente web debe alcanzar una puntuación de accesibilidad igual o superior a 90 sobre 100 en la auditoría automatizada, en perfil de escritorio y de móvil, tomando como referencia el nivel AA de las pautas WCAG 2.1.

Prioridad: Must

Fuente: WCAG 2.1 AA; criterio de calidad de la asignatura

Rationale: El sistema lo usa toda la comunidad universitaria de la carrera; la accesibilidad no es opcional. La auditoría automatizada no agota WCAG, y por eso el nivel de referencia se declara además del umbral numérico.

Criterio de aceptación: Puntuación de accesibilidad ≥ 90 en las corridas de escritorio y de móvil sobre el build de producción, con los informes archivados y fechados.

Método de verificación: Análisis

Estado: Verificado

Evidencia: Medición del 2026-09-06, 6 corridas: **100/100** en escritorio y en móvil. La corrida del 2026-08-17 daba 89, por debajo del umbral, y se corrigió.

RNF-24 Objetivos de respaldo y recuperación

Enunciado: El sistema debe garantizar un objetivo de punto de recuperación no superior a 24 horas y un objetivo de tiempo de recuperación no superior a 4 horas, y debe verificar la recuperabilidad de sus respaldos con una prueba de restauración al menos mensual.

Prioridad: Must

Fuente: docs/despliegue/BACKUP.md; criterio de continuidad de la asignatura

Rationale: Sin objetivos declarados, la funcionalidad de respaldo de RF-61 a RF-64 no tiene contra qué medirse: no se puede saber si una configuración es suficiente. El archivado del registro de escritura anticipada es lo que permite bajar el objetivo de punto de recuperación por debajo del intervalo entre respaldos completos.

Criterio de aceptación:

- El cronograma configurado en RF-62 arroja un objetivo de punto de recuperación declarado y no superior a **24 horas**.
- Existe al menos una prueba de restauración con resultado **EXITOSA** en los últimos 30 días, registrada conforme a RF-63.
- El tiempo medido de una restauración completa sobre datos de tamaño representativo es inferior a **4 horas**, con la medición archivada y fechada.
- El periodo de retención del archivado de escritura anticipada cubre al menos el intervalo entre dos respaldos completos consecutivos.

Método de verificación: Demostración + Análisis

Estado: **Verificado**

RNF-25 Reproducibilidad del entorno y determinismo de la siembra

Enunciado: Desde una clonación limpia del repositorio, el sistema debe poder construirse, desplegarse, migrarse, probarse y auditarse con una sola orden que termine con código de salida 0, y el estado inicial de los catálogos del dominio debe ser idéntico en dos despliegues independientes.

Prioridad: Should

Fuente: ADR-007; criterio de reproducibilidad de la asignatura

Rationale: La primera mitad está resuelta y verificada; la segunda no. Los estados de la solicitud y del cronograma se crean bajo demanda (nota de la sección 5), de modo que dos despliegues que ejecuten los casos de uso en orden distinto obtienen catálogos con identificadores distintos. Un sistema que se construye igual pero arranca distinto no es reproducible.

Criterio de aceptación:

- La orden única de reproducibilidad termina con código 0 desde una clonación limpia.
- Las imágenes de contenedor están ancladas por resumen criptográfico, no por etiqueta móvil.

- Los nueve estados de la solicitud y el estado del cronograma se **siembran por migración**, con identificador y orden fijos; ninguno se crea bajo demanda.

Método de verificación: Demostración + Inspección

Estado: **No cumplido**

Evidencia: La orden única está verificada de punta a punta con código de salida 0 (construcción, contenedores, migraciones, 559 pruebas, carga, auditoría, reportes y compilación del informe), y las imágenes están ancladas por resumen. El tercer criterio no se cumple.

RNF-26 Versionado uniforme de la API

Enunciado: Todos los endpoints de la API deben exponerse bajo un prefijo de versión único y explícito.

Prioridad: Should

Fuente: ADR-001

Rationale: Un prefijo aplicado a una parte de la API no versiona nada y además induce error en la documentación: 10 de los 15 endpoints que citaba la matriz anterior no resolvían precisamente porque se les había añadido un prefijo de versión que su controlador no tiene.

Criterio de aceptación: El 100 % de las rutas de la API responde bajo el prefijo de versión declarado; una petición a la ruta sin versionar responde 404 o redirige de forma permanente a la versionada.

Método de verificación: Inspección

Estado: **No cumplido**

Nota: En el punto de corte, **8 de 31** controladores exponen sus rutas bajo el prefijo de versión y los **23** restantes no, pese a que el archivo `README.md` declara la API como versionada. Es la causa directa del defecto de trazabilidad más extendido de la especificación anterior (§12).

9. Trazabilidad y verificación

9.1. Cláusula de verificación

Ninguna versión de este documento se publica si el validador de trazabilidad (`scripts/validate-traceability.sh`) no termina con código de salida 0. El validador es la garantía automática de que este SRS, la matriz y el árbol de archivos describen el mismo sistema; la revisión manual no puede sostener esa coherencia sobre 90 requisitos y 207 rutas.

Qué garantiza hoy, y desde cuándo. Las ocho comprobaciones de la tabla siguiente están **implementadas y activas desde el 2026-09-11**, y son las que el script ejecuta. Conviene ser explícito sobre el punto de partida: en la versión 1.0.0 de este documento la tabla enunciaba las ocho comprobaciones como especificación de lo que el validador *debía* hacer, mientras que el script publicado en el repositorio solo comprobaba que los archivos citados por cada fila existieran, y nunca abría el SRS. La revisión del docente-director señaló con razón esa distancia entre lo enunciado y lo

construido (M4). Esta versión la cierra: el validador lee el SRS, lo contrasta con la matriz en ambos sentidos y falla si discrepan.

Lo que el validador no garantiza. Que el enunciado de un requisito sea correcto, que su criterio de aceptación sea el adecuado o que la evidencia citada demuestre lo que dice demostrar. Eso es revisión humana y ninguna comprobación automática lo sustituye. El validador garantiza coherencia entre artefactos, no verdad de su contenido.

#	Comprobación que el validador realiza
V1	Toda fila de la matriz tiene exactamente el número de columnas de la cabecera, con los campos que contienen comas correctamente entrecomillados.
V2	La columna de estado contiene únicamente los cuatro valores del vocabulario cerrado de la sección 2.5; cualquier otro texto falla.
V3	Todo identificador de requisito de este SRS existe en la matriz, y todo identificador de la matriz existe en este SRS. El conteo debe coincidir.
V4	Todo endpoint citado en la matriz resuelve contra un controlador real: se comprueba la ruta completa , método y camino, no solo su primer segmento.
V5	Toda clase de prueba citada existe como archivo en disco.
V6	Todo archivo de historia de usuario o de caso de uso citado existe como archivo en disco.
V7	Ningún requisito declarado <i>Verificado</i> carece de prueba automatizada o de evidencia archivada.
V8	Ningún requisito declarado <i>Planificado</i> cita un endpoint existente: si el endpoint existe, el requisito está al menos implementado.

Cuadro 6: Las ocho comprobaciones, implementadas y activas desde el 2026-09-11. V1 a V6 son las que habrían detectado, antes de la entrega, los defectos que la sección 12 documenta, y V3 es la que convierte una matriz incompleta en un error de construcción en vez de en un hallazgo de auditoría.

9.2. Salida del validador sobre este árbol

Reproducible con `./scripts/validate-traceability.sh` desde la raíz del repositorio:

```

Requisitos en el SRS ..... 90
Filas en la matriz ..... 90
Endpoints reales del backend ..... 213
Clases de prueba en disco ..... 53
Estados: Implementado 14, No cumplido 3, Planificado 2, Verificado 71
Must verificados ..... 47/50 (94 %)
=== V1-V8: sin fallos. Trazabilidad consistente. ===

```

Todas las cifras de la sección 10 son esta salida, no un conteo manual sobre el documento. Si el documento y la matriz dejan de coincidir, el validador falla y la cifra no llega a publicarse.

9.3. Estructura de la matriz de trazabilidad

La matriz (`docs/trazabilidad/matriz.csv`) conecta cada requisito con su origen y su evidencia. Sus columnas son:

Columna	Contenido
ID_Requisito	Identificador RF- nn o RNF- nn de este documento.
Título	Título del requisito, idéntico al de este documento.
Fuente	Historia de usuario, caso de uso, decisión de arquitectura o norma.
Modulo	Módulo funcional del sistema.
Endpoint_REST	Método y ruta completa, tal como responde el servicio.
Prioridad_MoSCoW	<i>Must</i> , <i>Should</i> o <i>Could</i> .
Metodo_Verificacion	Prueba, Demostración, Análisis o Inspección.
Caso_Prueba	Clase o clases de prueba, o ninguna .
Estado	Uno de los cuatro valores del vocabulario cerrado, y ningún otro.
Evidencia	Ruta del artefacto de evidencia con su fecha.
Observaciones	Todo matiz que no cabe en el vocabulario cerrado de estado.

La columna **Observaciones** es nueva y existe por una razón concreta: es donde va el matiz que antes se colaba dentro de la columna de estado y rompía el vocabulario.

10. Estado de cumplimiento del corpus

10.1. Distribución por estado y prioridad

	Verificado	Implementado	Planificado	No cumplido	Total
Requisitos funcionales	51	13	0	0	64
Requisitos no funcionales	20	1	2	3	26
Total	71	14	2	3	90

Cuadro 7: Distribución por estado. Cifras producidas por el validador sobre la matriz completa (sección 9.2), no contadas a mano sobre el documento.

	Must	Should	Could	Total
Requisitos funcionales	30	26	8	64
Requisitos no funcionales	20	6	0	26
Total	50	32	8	90

Cuadro 8: Distribución por prioridad MoSCoW. No hay requisitos *Won't*: una capacidad descartada se retira del alcance, no se conserva como requisito con etiqueta de descarte.

10.2. Requisitos *Must* que no están verificados

De los **50** requisitos de prioridad *Must*, **47 están verificados (94,0 %)**. Los **3** restantes se enumeran aquí de forma completa, porque un porcentaje sin el detalle de lo que falta no es información accionable.

ID	Requisito	Estado	Qué falta
RF-05	Recuperación de contraseña	Implementado	Activar SMTP real y verificar que el correo de recuperación llega de verdad (hoy <code>app.mail.enabled=false</code>).
RNF-19	Retención y supresión de datos	Implementado	Conservar formularios de consentimiento firmados reales cuando existan (política ya declarada; hoy no hay ninguno que conservar).
RNF-11	Transporte cifrado	Planificado	Depende del despliegue público, aún no realizado.

Cuadro 9: Los 3 requisitos *Must* no verificados, con lo que falta en cada uno.

Ninguno de los tres exige ya cambiar código: los tres son de evidencia, configuración o despliegue – RF-05 (activar SMTP y verificar la entrega), RNF-11 (depende del despliegue público, aún no realizado) y RNF-19 (conservar formularios de consentimiento reales cuando existan; la política ya está declarada). Los tres, junto con el resto de la deuda declarada, siguen el orden de la sección 13.

10.3. Nota metodológica sobre el crecimiento del corpus

El corpus pasó de los 16 requisitos de la especificación anterior a los 90 de esta. Conviene ser preciso sobre qué significa esa cifra, porque se presta a dos lecturas opuestas y solo una es correcta.

No es alcance nuevo. De los 74 requisitos añadidos, **69 documentan capacidades o propiedades que ya estaban construidas** en el repositorio y que sencillamente no tenían requisito que las especificara. Solo **5** describen algo que aún no existe o no puede verificarse todavía: RF-05 y RF-06 (credenciales del usuario), RNF-19 (retención y supresión), RNF-22 (usabilidad medida) y RNF-11 (transporte cifrado, a la espera del despliegue público). La tasa de adición no mide crecimiento del producto: mide cuánto le faltaba a la especificación para alcanzar al código.

Es, sin embargo, una señal sobre el proceso. Que un SRS describiera 16 requisitos de un sistema con 207 rutas significa que durante la mayor parte del desarrollo el documento dejó de funcionar como contrato y como base de verificación. En un proyecto con interesados externos, una desviación de esta magnitud detectada al cierre de una entrega sería una señal de alarma sobre la especificación continua, no un logro de la revisión final. Se declara aquí y se remite al capítulo de amenazas a la validez del informe.

Estabilidad del corpus heredado. De los 16 requisitos de la especificación anterior, 15 se conservan con el mismo alcance (renumerados y completados con la plantilla) y 1 cambia de prioridad con justificación (RF-37, de *Should* a *Must*). Ninguno se retira. La estabilidad del corpus heredado es del **93,8 %**; no debe sumarse ni compararse con la tasa de adición, porque miden cosas distintas.

11. Correspondencia con el Anexo C de ISO/IEC/IEEE 29148:2018

Este documento declara conformidad con la norma, de modo que debe poder contrastarse con el esquema que la norma propone. La estructura elegida no es idéntica a la del Anexo C; esta tabla mapea cada elemento del esquema normativo a la sección donde vive, y justifica cada desviación en vez de dejarla implícita.

Elemento del Anexo C	Sección de este SRS	Desviación y justificación
Propósito	§2.1	Sin desviación.
Alcance	§2.2	Sin desviación. Se añade el alcance excluido de forma explícita.
Definiciones y acrónimos	§2.3	Sin desviación.
Referencias	§2.7	Sin desviación.
Perspectiva del producto	§3.1	Sin desviación.
Funciones del producto	§7	Se antepone el catálogo de estados (§5) y la matriz de permisos (§6) porque los criterios de aceptación de §7 los usan como vocabulario.
Características de los usuarios	§3.2	Se distingue rol de cuenta de rol funcional, distinción que la norma no exige pero sin la cual el control de acceso de RF-37 no es especificable.
Restricciones	§3.3	Separadas de los requisitos, conforme a la norma.
Supuestos y dependencias	§3.4	Sin desviación.
Interfaces externas	§4	Se separa interfaz expuesta de interfaz consumida, y se exige a cada consumida un comportamiento declarado ante indisponibilidad.
Requisitos funcionales	§7	Sin desviación.
Requisitos de rendimiento	§8.1	Agrupados como no funcionales, con umbral y condición de carga.

Elemento del Anexo C	Sección de este SRS	Desviación y justificación
Requisitos lógicos de base de datos	§5	Desviación: no hay una sección de modelo lógico. El ciclo de vida de los datos se especifica como máquinas de estado, que es lo que los criterios de aceptación necesitan; el modelo físico vive en las migraciones versionadas y su catálogo de rutinas, referenciados en §2.7.
Restricciones de diseño	§3.3	Sin desviación.
Atributos del sistema: fiabilidad y disponibilidad	§8.1 (RNF-04), §8.4 (RNF-24, RNF-25)	Sin desviación.
Atributos del sistema: seguridad	§8.2	Sin desviación. Se mapea cada requisito a su control de referencia externo.
Atributos del sistema: mantenibilidad y portabilidad	§8.4	Portabilidad cubierta por RD-04 y RNF-25 en vez de por requisitos propios.
Usabilidad	§8.4 (RNF-22, RNF-23)	Desviación: usabilidad y accesibilidad se especifican como requisitos con umbral medible en vez de como sección propia, para que estén sujetas al mismo vocabulario de estado que el resto.
Verificación	§9.1	Se declara como cláusula ejecutable (validador con código de salida 0), no solo como enunciado de intención.
Trazabilidad	§9.2 y <code>matriz.csv</code>	Sin desviación.
Información de soporte	§14, §15	Anexos de INCOSE y elicitación por referencia, para que las dos copias no puedan divergir.

Cuadro 10: Correspondencia con el esquema del Anexo C.

Cuatro desviaciones declaradas, cada una con su justificación.

12. Correcciones

Esta sección documenta qué se corrigió y por qué, para que la bitácora de cambios no sea la única constancia. Cubre dos ciclos distintos: la respuesta a la revisión del docente-director sobre la versión 1.0.0 (§12.1) y las correcciones que la propia 1.0.0 hizo sobre los borradores que la precedieron (§12.2 en adelante). El detalle por requisito está en `docs/requisitos/CHANGELOG-REQ.md`.

12.1. Respuesta a la revisión del docente-director sobre la versión 1.0.0

La versión 1.0.0 fue revisada por el docente-director, que emitió ocho observaciones de modificación y cuatro de adición. Esta subsección responde a cada una: qué señalaba, qué se hizo y dónde queda la constancia. Cuando la observación era inexacta se dice también eso, con el dato que la corrige, porque aceptar en silencio una observación que no corresponde deja el documento peor de lo que estaba.

Causa raíz de cinco de las ocho observaciones. M1 a M5 señalaban que la matriz de trazabilidad cubría 15 de los 90 requisitos, con nueve columnas en vez de once y dos valores de estado en vez de cuatro, y que el validador no realizaba ninguna de las comprobaciones V1 a V8. Las cinco eran correctas, y las cinco tenían el mismo origen: **la matriz y el validador que esta especificación describe nunca llegaron a la rama principal del repositorio**. La revisión se hizo, con toda razón, sobre lo que había publicado —los artefactos del borrador del 2026-08-17—, mientras el documento revisado era el nuevo. No era una discrepancia entre lo escrito y lo construido: era una entrega incompleta. Los artefactos se publican con esta versión, y la comprobación V3 convierte esa clase de desfase en un error de construcción.

Obs.	Qué señalaba	Qué se hizo
M1 / A1	La matriz cubre 15 de 90 requisitos.	Aceptada. Se publica la matriz completa: 90 filas, una por requisito, con método de verificación y evidencia.
M2	La matriz descrita (11 columnas) no es la que existe (9 columnas con otros nombres).	Aceptada. El archivo publicado tiene exactamente las once columnas que describe §9, incluida Observaciones .
M3	El vocabulario cerrado de cuatro estados no existe en la matriz, que solo usa dos.	Aceptada. La columna Estado usa los cuatro valores de §2.5, y la comprobación V2 rechaza cualquier otro.
M4 / A2	El validador no realiza ninguna de las comprobaciones V1 a V8; nunca abre el SRS.	Aceptada. Las ocho están implementadas y activas. La cláusula de §9 se reescribió para declarar qué garantiza el validador, desde cuándo y qué no garantiza.
M5	La distribución de estados no es reproducible desde el repositorio.	Aceptada. Las cifras son ahora la salida literal del validador (§9.2), con el comando que las reproduce.

Obs.	Qué señalaba	Qué se hizo
M6	Se citan HU-13, HU-14 y HU-15, que no existen.	Aceptada en parte. Era cierto en la matriz publicada, ya sustituida. No lo era en el documento: la única mención a esas tres historias estaba en §12.2, describiendo un defecto ya corregido. Esa frase se reformuló para que no pueda leerse como cita viva.
M7 / A3	Con 64 requisitos y 12 historias, la mayoría del corpus no tiene origen declarado.	Aceptada en el fondo, matizada en la forma. Ningún requisito tenía el campo Fuente vacío, pero 27 declaraban «historia de usuario pendiente», que es una promesa y no una fuente. Los 27 declaran ahora su origen real y verificable: la migración que creó su tabla o su permiso, la decisión de arquitectura, el control OWASP, el reglamento de titulación o la observación docente que lo motivó. Ver §13.
M8	La autoría del documento no está reconciliada con el historial del repositorio, y la frase de la portada no debería estar ahí.	Aceptada. La portada identifica al autor y su ORCID, sin ninguna otra declaración. La situación del equipo se explica como nota de alcance en §1.3, y las menciones a «el equipo» que quedaban en el cuerpo se reconciliaron.
A4	Falta un requisito que fije qué ocurre con las credenciales de ejemplo.	Aceptada como refuerzo. El requisito ya existía —RNF-15, en estado No cumplido — pero solo cubría el código fuente. Se amplió con dos criterios que alcanzan todo artefacto versionado, y se le declaró como fuente la observación docente OBS-11, que sigue abierta en parte desde la Entrega 3.

Cuadro 11: Respuesta a las doce observaciones de la revisión de la versión 1.0.0.

Una precisión sobre una cifra de la revisión. La revisión da por buena la cifra de «207 rutas en 49 controladores». Las 207 rutas son correctas; los 49 controladores salen de contar los 31 de `src/main/java` más las 18 clases de prueba de controlador de `src/test`, que no exponen ninguna ruta. El par que este documento sostiene es **31 controladores de producción y 207 rutas**, y así queda aclarado en §3.1 para que la diferencia no vuelva a aparecer.

12.2. Defectos de trazabilidad corregidos en la versión 1.0.0

1. **Diez de los quince endpoints citados en la matriz no resolvían.** Todos llevaban un prefijo de versión que su controlador no tiene: la matriz citaba, por ejemplo, la ruta versionada de la creación de solicitud, del cronograma, de la evaluación, del acta, de los reportes, de las salas, de los usuarios y del anteproyecto, y ninguna de ellas existe. La causa raíz es RNF-26. Corregido: los 207 endpoints de este documento se citan con la ruta real.
2. **Tres historias de usuario citadas no existían como archivo.** La matriz de la especificación anterior referenciaba HU-13, HU-14 y HU-15, y el directorio contiene únicamente HU-01 a HU-12. **Ya corregido: ni este documento ni la matriz que lo acompaña citan hoy ninguna de las tres**, y la mención que se hace de ellas en este párrafo describe un defecto cerrado, no una referencia viva. La comprobación V6 del validador lo impide en adelante.
3. **El SRS y la matriz declaraban conjuntos distintos.** El documento hablaba de 12 requisitos y la matriz contenía 15 filas, en la misma versión. Corregido: los dos artefactos contienen los mismos 90 identificadores, y la comprobación V3 lo verifica en integración continua.
4. **El validador no detectaba ninguno de los tres problemas anteriores.** Comprobaba el endpoint quedándose con el **primer segmento** de la ruta tras descartar el prefijo, de modo que una ruta versionada inexistente coincidía con el controlador sin versionar y pasaba sin protestar. Ese era el único punto ciego de un mecanismo que por lo demás funcionaba. Corregido con las comprobaciones V1 a V6 y V8 de la sección 9.

12.3. Estados declarados que ya no correspondían

1. **La cobertura de pruebas.** La especificación anterior declaraba 38,88 % de líneas y «no cumplido» contra un umbral de 60 %. La medición vigente en ese mismo momento ya era otra, y la del punto de corte es de **81,03 %** de líneas con 559 pruebas. El requisito pasa a **Verificado** con umbral elevado al 70 % de líneas y de ramas (RNF-21). La cifra ahora va fechada dentro del propio requisito.
2. **La accesibilidad.** No existía requisito que la exigiera pese a medirse. Se especifica con umbral y nivel de referencia (RNF-23), y se declara verificada con 100/100.
3. **El rendimiento del cliente web.** Tampoco existía requisito. Se especifica (RNF-02) y se declara **No cumplido** con la cifra real, en vez de omitir la medición que no alcanza el umbral.

12.4. Cobertura: de 16 requisitos a 90

La especificación anterior describía 16 requisitos de un sistema con 31 controladores y 207 rutas. Módulos completos no tenían ninguna línea que los describiera: respaldo y recuperación, bitácora de auditoría, catálogos académicos, gestión de estudiantes, centro de orientación, tutoría por fases, asistente virtual, estado en tiempo real, roles y permisos, y buena parte del ciclo de vida de la solicitud y del acta. Esta versión los especifica. Ninguno exigió programar: solo especificar lo que ya estaba programado.

12.5. Secciones estructurales incorporadas

Cinco secciones que la norma espera y el documento no tenía: interfaces externas (§4), catálogo de estados del dominio (§5), matriz de permisos rol × operación (§6), correspondencia con el Anexo C (§11) y cláusula de verificación (§9.1). Las dos que más falta hacían son §5 y §6: los criterios de aceptación usaban nombres de estado nunca definidos, y con 29 permisos repartidos entre 207 rutas la autorización ya no se podía auditar leyendo requisito por requisito.

12.6. Lenguaje y forma

Se fija la convención de redacción normativa (§2.4), se cierra el vocabulario de estado (§2.5) y de método de verificación (§2.6), se expresan los criterios de aceptación como respuesta observable en vez de como excepción interna, y se retiran del enunciado las rutas de archivo y los nombres de clase, que pasan a la matriz donde el validador los comprueba contra el disco.

13. Deuda declarada y plan de cierre

Salvo donde se marca explícitamente cerrado, nada de lo que sigue está resuelto. Se enumera de forma completa porque un hallazgo sin registro no tiene fecha de cierre, y porque declararlo es preferible a que aparezca en una revisión externa. La numeración se conserva estable a través de las fases de cierre (no se reenumeran los puntos ya cerrados) para que las referencias a .el punto N.^{en} el historial de cambios sigan siendo válidas.

13.1. Orden de trabajo propuesto

1. **Seguridad inmediata — cerrado en la fase 4 (2026-09-11).** RNF-15 (contraseñas literales en el código de un repositorio público y siembra de cuentas en todo arranque) y RNF-04 (la revocación de tokens era *fail-open*). Eran los dos únicos hallazgos que degradaban la seguridad del sistema desplegado; ambos se cerraron con un cambio acotado (`DemoDataSeeder/AdminBootstrap` para RNF-15, *fail-closed* explícito en revocación y límite de tasa para RNF-04). Se conserva este punto, marcado como resuelto, para no reenumerar los siguientes.
2. **Credenciales del usuario — cerrado en la fase 6 (2026-09-11).** RF-06 (cambio propio, fase 5) y RF-05 (recuperación sin sesión, fase 6) ya existen como funcionalidad real y probada, y RNF-06 (política de contraseñas) se aplica en los tres puntos que su criterio exige: alta, cambio y restablecimiento. Único cabo suelto, declarado y no oculto: RF-05 queda **Implementado**, no **Verificado**, porque la entrega real del correo de recuperación nunca se verificó contra un servidor SMTP (ver su nota) – activarlo y comprobarlo es un pendiente aparte, de infraestructura, no de construcción. Se conserva este punto, marcado como resuelto, para no reenumerar los siguientes.
3. **Protección de datos personales — 3 de 4 criterios cerrados en la fase 7 (2026-09-11).** RNF-19: tabla de retención publicada (`docs/etica/RETENCION-DATOS.md`), depuración automática de la bitácora sin endpoint (resuelve la tensión con RNF-18) y procedimiento de supresión por seudonimización, los tres construidos y probados. Sigue abierto, y es genuinamente de infraestructura/proceso, no de código: no existe todavía ningún formulario de consentimiento

firmado real que conservar (la política de conservación de 2 años ya está declarada en **ETHICS.md** §3 desde antes de esta fase). Por eso RNF-19 queda **Implementado**, no **Verificado**. Se conserva este punto para no reenumerar los siguientes.

4. **Comprobaciones del validador.** Implementar V1 a V6 y V8 (§9). Son pocas líneas y son lo que impide que esta revisión se repita: las seis habrían detectado solas los cuatro defectos de §12.
5. **Continuidad.** RNF-24, RF-61 y RF-63: medir el tiempo de restauración, archivar la evidencia de una prueba exitosa y verificar que el archivado de escritura anticipada sostiene el objetivo de punto de recuperación declarado.
6. **Despliegue y transporte.** RNF-11, que hoy no puede verificarse porque el sistema no está desplegado públicamente, y RNF-02, cuyo plan de cierre es la fragmentación del paquete de JavaScript del cliente.
7. **Coherencia interna.** RNF-25 (sembrar por migración los estados de la solicitud y del cronograma), RNF-26 (unificar el prefijo de versión de la API) y la revisión permiso a permiso de la asignación del Coordinador (§6.4, punto 4).

13.2. Origen de los requisitos sin historia de usuario

Treinta y uno de los 64 requisitos funcionales tienen una historia de usuario formal (HU-01 a HU-12); los otros 33, más los 26 no funcionales, no la tienen. Eso **no** significa que carezcan de origen: en la versión 1.0.0 declaraban «auditoría de cobertura, historia de usuario pendiente», que es una promesa y no una fuente, y esta versión sustituye esa fórmula por el **origen real y verificable** de cada uno —la migración que creó su tabla o su permiso, la decisión de arquitectura que lo impuso, el control OWASP, el reglamento de titulación, la observación docente o el criterio de la asignatura—. Ninguno queda sin origen demostrable.

Escribir además la historia de usuario de esos 33 sigue siendo trabajo deseable, y por eso permanece en esta sección: una historia añade el «para qué» desde la voz del actor, que una migración no expresa. Pero es una mejora de la elicitación, no un hueco de trazabilidad: hoy todo requisito puede demostrar de dónde viene, y la comprobación V6 del validador impide citar una historia que no exista en disco.

13.3. Defectos funcionales menores declarados

1. **Ruta de la *cookie* de renovación.** La *cookie* del token de renovación se emite con un ámbito de ruta que no coincide con el del endpoint que la consume, de modo que el navegador no la envía en la petición de renovación. Afecta a RF-02.
2. **Estado SUSPENDIDA sin retorno.** No existe la reanudación de una solicitud suspendida (RF-16), de modo que una suspensión es hoy tan definitiva como un rechazo.
3. **Ruta de progreso desacoplada del expediente.** Los ocho pasos de RF-51 se marcan manualmente y pueden contradecir el estado real de la solicitud.
4. **Permiso inadecuado en las estadísticas de tutoría.** RF-58 se protege con un permiso de la categoría Evaluación.

5. **Colisión de identificadores en el catálogo de permisos.** Dos migraciones asignaron el mismo identificador a permisos distintos; la inserción posterior se descartó en silencio y hubo que repararla con una migración adicional. No hay efecto vigente, pero el catálogo no es reproducible por simple lectura de las migraciones en orden.
6. **Salvaguarda de administración.** RF-12 permite retirar al rol de Administrador el permiso de gestionar permisos, dejando el sistema sin ningún usuario capaz de revertirlo.

14. Anexo: *checklist* INCOSE

Las 9 características de calidad individuales de INCOSE (Necesario, Apropiado, No ambiguo, Completo, Singular, Factible, Verificable, Correcto, Conforme) y las 6 del conjunto se aplican al corpus completo. El *checklist* vive en `docs/checklists/INCOSE-REQUIREMENTS.md` y se anexa por referencia, no verbatim, para que las dos copias no puedan divergir.

Brechas conocidas del corpus de esta versión: la característica *Correcto* no puede afirmarse para los 5 requisitos en estado **Planificado**, que describen comportamiento aún no construido; y *Verificable como conjunto* está limitada por los 19 requisitos en estado **Implementado**, cuyo criterio no tiene todavía prueba ni evidencia archivada. La característica *Conforme*, que era la brecha más consistente de la especificación anterior por usar formato de historia de usuario en vez de lenguaje normativo, queda cerrada con la convención de §2.4.

15. Anexo: técnicas de elicitación aplicadas

Detalle completo en `docs/requisitos/elicitation/README.md`. De las cinco técnicas esperadas, **dos tienen evidencia real y verificable** en el repositorio (análisis de documentos, con observaciones docentes trazadas a *commits* reales, y evaluación cruzada de pares), **una es parcial** (prototipado iterativo evidenciado por el historial de control de versiones, sin sesiones formales documentadas) y **dos no tienen evidencia documentada** (entrevistas y observación directa). Se declara explícitamente en vez de fabricar transcripciones o actas que no existieron.

A estas se suma, en esta versión, una técnica que sí produjo la mayor parte del corpus nuevo: la **ingeniería inversa de requisitos** sobre el código, las migraciones y la configuración del sistema construido. Es una técnica legítima de elicitación cuando la implementación precede a la especificación, y declararla es más honesto que atribuir a entrevistas inexistentes unos requisitos que se obtuvieron leyendo el repositorio.

16. Página de aprobación

Elaborado por	Revisado y aprobado por (Docente-Director)
Álava Alvarado, Jean Pierre ORCID: 0009-0001-2878-2919	Ing. Guerrero Ulloa Gleiston Cícron, Mg.
Fecha: _____	Fecha _____ de _____ aprobación: _____

Estado real de la firma (2026-09-11): la firma del docente-director **no se ha obtenido todavía** para esta versión. La v1.0.0 sí fue revisada por el docente-director, y esta v1.0.1 es la respuesta a esa revisión (sección [12.1](#)); la aprobación formal queda pendiente de su nueva lectura. No se fabrica una firma ni se marca esta sección como completa hasta que ocurra realmente, siguiendo la misma política de integridad aplicada al resto del documento: donde no hay evidencia, se declara que no la hay.